

CPE 334 | Lab 3 submission report

TokTickIT – Users, Roles, IT Staff Ticketing, and Admin Screens

Author: Garunyapas Danpitakkul (Vieng), 67070503404, @vienggg

Recorded GitHub reviewer: @projectnewy; originally designated course peer: Dechayut, 67070503414, @NinjoMUDA (identity relationship unverified)

Repository: github.com/vienggg/toktickit

Kanban: TokTickIT Kanban

Release: PR #71, reviewed and merged into main at e48d2c8; tag lab3-release

DRAFT: I-II review/merge, all-Done board image, and final main-branch E2E output remain pending. Do not submit this draft.

Answer Part 1: Git Use with Engineering Workflow

Each Lab 3 issue used a dedicated branch into lab3-staging; PR #71 integrated staging into main. PR #72 carried the release-review corrections. One direct staging push (047b5bf) violated the intended flow and is recorded honestly in the peer-review log.

```
docs/lab3-spec-and-test-plan -> PR #62 -> lab3-staging
feature/lab3-* -> PRs #63-#70 -> lab3-staging
feature/lab3-release-review-fixes -> PR #72 -> lab3-staging
lab3-staging -> PR #71 -> main (e48d2c8) -> lab3-release tag
docs/lab3-report-final -> I-11 / issue #60 (pending peer review)
```

The release commit graph preserves the peer-reviewed branches and merges (short SHAs from `git log --graph --oneline origin/main`):

```
e48d2c8 Merge PR #71: lab3-staging -> main (lab3-release)
 9a98cb5 Merge PR #72: release-review-fixes -> lab3-staging
   ab7495e fix(lab3): address release review findings
 8af35e8 Merge PR #70: e2e-and-visual -> lab3-staging
 2354b35 Merge PR #69: user-administration -> lab3-staging
 f999d18 Merge PR #68: staff-ticket-detail -> lab3-staging
 6eaccff Merge PR #67: staff-queue -> lab3-staging
 ec8c65a Merge PR #64: auth-foundation -> lab3-staging
[See the linked PRs and repository History for the complete graph]
```

Repository layout at the release commit (`git ls-tree`), including the required evidence folders:

```
toktickit/
 README.md .gitignore client/ server/ e2e/lab-03/
 docs/lab-03/{specification,api-spec,ui-spec,tests,reviewer,ai-use}.md
 artifacts/lab-03/screenshots/
   authentication/ staff-queue/ staff-ticket-detail/ user-management/
```

Missing evidence: artifacts\lab-03\report-evidence\kanban-all-done.png

Peer-review source: `reviewer.md`.

Rendered document: docs/lab-03/reviewer.md

Lab 3 — Peer Review Record

Author: Garunyapas Danpitakkul (Student ID: 67070503404, GitHub: @vienggg) Recorded GitHub reviewer and merger: @projectnewy (PRs #61–#72) Originally designated course peer: Dechayut (Student ID: 67070503414, GitHub: @NinjoMUDA). Whether this is the same person as @projectnewy has not been independently verified. Partner Repository: https://github.com/NinjoMUDA/Dechayut_3414Lab1 Project Repository: <https://github.com/vienggg/toktickit>

This log is appended after every merged PR, not written retroactively at the end of the sprint — see docs/lab-03/sprint-plan.md §1 (Law 2) for why.

1. Pull Requests Authored (reviewed and merged by @projectnewy on GitHub)

PR #: #61 | Title: chore(lab3): Sprint 3 infrastructure setup
Feature Branch: chore/lab3-phase0-infra
Target Branch: lab3-staging
Status & Verdict: Approved & Merged

PR #: [#62](#) | Title: docs(lab3): Sprint 3 engineering contract
Feature Branch: docs/lab3-spec-and-test-plan
Target Branch: lab3-staging
Status & Verdict: Approved & Merged

PR #: [#63](#) | Title: feat(lab3): data model, migration, and seed for Users, Roles, and Ticket workflow
Feature Branch: feature/lab3-user-model-and-migration
Target Branch: lab3-staging
Status & Verdict: Approved & Merged

PR #: [#64](#) | Title: feat(lab3): authentication foundation — login, logout, me, change-password
Feature Branch: feature/lab3-auth-foundation
Target Branch: lab3-staging
Status & Verdict: Approved & Merged

PR #: [#65](#) | Title: feat(lab3): auth UI, routing, and Requester regression
Feature Branch: feature/lab3-auth-shell-and-regression
Target Branch: lab3-staging
Status & Verdict: Changes Requested Fixed Approved & Merged

PR #: [#66](#) | Title: feat(lab3): Requester Public Comments and resolution signal
Feature Branch: feature/lab3-requester-comments
Target Branch: lab3-staging
Status & Verdict: Changes Requested Fixed Approved & Merged

PR #: [#67](#) | Title: feat(lab3): IT Staff Ticket Queue
Feature Branch: feature/lab3-staff-queue
Target Branch: lab3-staging
Status & Verdict: Changes Requested Fixed Approved & Merged

PR #: [#68](#) | Title: feat(lab3): IT Staff Ticket Detail
Feature Branch: feature/lab3-staff-ticket-detail
Target Branch: lab3-staging
Status & Verdict: Changes Requested Fixed Approved & Merged

PR #: [#69](#) | Title: feat(lab3): Administrator User Management
Feature Branch: feature/lab3-user-administration
Target Branch: lab3-staging
Status & Verdict: Changes Requested Fixed Approved & Merged

PR #: [#70](#) | Title: feat(lab3): E2E specs, full screenshot manifest, visual inspection
Feature Branch: feature/lab3-e2e-and-visual
Target Branch: lab3-staging
Status & Verdict: Changes Requested Fixed Merged 2026-09-18

PR #: [#72](#) | Title: fix(lab3): address PR #71 release review
Feature Branch: feature/lab3-release-review-fixes
Target Branch: lab3-staging
Status & Verdict: Approved and merged 2026-10-05 01:00 ICT

PR #: [#71](#) | Title: Lab 3 release integration
Feature Branch: lab3-staging
Target Branch: main
Status & Verdict: Changes Requested, then Approved and merged 2026-10-05 01:01 ICT

(Rows are appended, and PR numbers/links/verdicts filled in, as each Issue's PR is actually opened and reviewed. This table is never pre-filled with predicted outcomes.)

Note on reviewer identity: The actual reviews and merges on GitHub were performed by @projectnewy. The original plan named Dechayut/@NinjoMUDA; the relationship between those identities is unverified, so this document does not claim they are the same person.

2. Substantive Review Comments Received & Responses

PR #65: Auth UI, routing, and Requester regression — Changes Requested (@projectnewy, 2026-09-16)

Reviewer Feedback: *Nine findings, ranked by severity, three called out as blocking: (1) the /uploads static mount was still live alongside the new authenticated download endpoint, so the ownership/removal-state gap the PR claimed to close was still open via the old path; (2) the ownership check (!ticket || ticket.requesterId !== req.authUser!.id) was hand-rolled inline in three places instead of reusing the existing findOwnedTicketOr404 helper, risking future divergence; (3) GET /api/auth/me silently dropped department on every call after the initial login response; (4) the attachment-upload route ran multer's disk-write middleware before the ownership check, so a non-owner's rejected upload still left an orphaned file on disk; (5) no non-owner regression test existed for the POST/DELETE attachment routes, only GET and download; (6) tests.md's API-10d row claimed 401 coverage across categories/systems/attachments/PATCH that didn't actually exist, and no systems test file existed at all; (7) my-tickets and ticket-detail tests both mutated the same real seeded user's mustChangePassword flag, race-prone under Vitest's cross-file parallelism; (8) the Navbar brand-click target changed from 'create' to 'list' with no explanation; (9) checkSystem() fetches /api/categories without credentials: 'include', which is now behind requireAuth.*

Author Response (@vienggg): *All nine addressed on the same branch. (1) Removed the express.static("/uploads", ...) mount entirely — nothing client-side referenced it any more, and the download endpoint doesn't need it (it streams from disk directly). (2)+(4) Replaced all four inline/duplicated ownership checks with one requireOwnedTicketParam middleware, applied to all five ticket-scoped routes (GET/PATCH/POST-attachments/DELETE-attachment/download) ahead of upload.array(), so ownership is confirmed before multer ever writes a file. (3) Added department to the authUser object requireAuth builds. (5) Added API-12c/API-13a: non-owner POST returns 404 and writes no file (asserted via before/after attachment count); non-owner DELETE returns 404. (6) Created server/tests/lab-01/systems.test.ts*

(didn't exist) and added the missing 401 tests for PATCH, POST/DELETE attachments, and the download route; corrected the tests.md row to describe what's actually tested and where. (7) Added a second dedicated test fixture (REGRESSION_OTHER_REQUESTER_* in testAuth.ts) with mustChangePassword already false, so ticket-detail.api.test.ts's "someone else" scenario no longer touches any real seeded user or shared mutable state at all. (8) Reverted the brand-click target to 'create' (Lab 2 behavior) — the change was unintentional drift, not a decision. (9) Added credentials: 'include' to checkSystem()'s /api/categories call. All 68 server tests (+6 new) and 17 client tests pass.

PR #66: Requester Public Comments and resolution signal — Changes Requested (@projectnewy, 2026-09-16)

Reviewer Feedback: Eight findings, two blocking. (1) ``POST .../resolution-signal`` had no idempotency guard — the 409 check only covered terminal status, never whether requesterResolvedAt was already set, so a double-click or retry on a still-open ticket overwrote the timestamp and created a duplicate comment every time; the terminal-status read was also not re-checked inside the transaction, so it wasn't atomic. (2) the new `requireTicketVisibleToUser/findVisibleTicketOr404` reimplemented the same 404-masking logic PR #65 had just consolidated into one helper, reintroducing a second independent copy. (3) the client's `RESOLUTION_TERMINAL_STATUSES` list had dead entries (two raw uppercase values that can never reach the client once `serializeTicket`'s legacy mapping runs) and wasn't derived from any shared source with the server's own list. (4) `fetchComments` silently swallowed a non-ok response, unlike `fetchTicketDetail`'s handling in the same file. (5) `handlePostComment/handleSignalResolution` discarded their POST response and re-fetched instead — the resolution handler's re-fetch of the whole ticket also flipped `isLoading` and unmounted the detail view. (6) the resolution route reused the heavy `findOwnedTicketOr404` (with joins) for a handler that only reads `id/status`. (7) `parseInt(req.params.id, 10)` accepts trailing garbage (`"5abc" 5`) — a pre-existing pattern copy-pasted into the new route rather than fixed. (8) `authorRole` was fetched and typed on the client but never rendered.

Author Response (@vienggg): All eight addressed on the same branch.

(1) Rewrote the guard as a single conditional `updateMany(`WHERE id = ? AND status NOT IN (...) AND requesterResolvedAt IS NULL`)` inside the

transaction — atomic by construction, since Postgres serializes concurrent UPDATES on the same row and the second one's WHERE simply won't match once the first has committed. Added API-18f testing a second call is rejected and creates no duplicate. (2) Introduced one shared fetchAuthorizedTicket core, parameterized by an authorization predicate and a fetch strategy; findOwnedTicket (strict ownership, full detail), findOwnedTicketLight (strict ownership, no joins), and findVisibleTicket (role-aware visibility, no joins) are now three thin call sites over that one core. (3) Moved the status list to the server as the single source of truth and added a computed canSignalResolution boolean to serializeTicket's output; the client reads that flag directly and no longer duplicates any status logic. (4) fetchComments now sets a visible error on a non-ok response. (5) Both handlers now read the POST/resolution-signal response directly — the resolution route was changed to also return the created comment so the client never needs a follow-up request for either action. (6) Resolution-signal now uses findOwnedTicketLight. (7) Added a parseStrictId helper (regex-validated, not parseInt's permissive trailing-garbage behavior) and applied it to every :id/:attachmentId route param in the file, not just the new I-5 routes. (8) authorRole is now rendered as a small badge next to the author's name for any non-Requester author. All 82 server tests (+1 new) and 19 client tests pass.

PR #67: IT Staff Ticket Queue — Changes Requested (@projectnewy, 2026-09-17)

Reviewer Feedback: Eight findings, two blocking. (1) the "Open" action's default navigate('/staff/tickets/:id') pointed at a route that does not exist in App.tsx, so every click on the queue's one specified action silently fell through to the Requester's own workspace instead of a ticket detail view — and no test exercised the click at all. (2) the Owner filter only offered "All"/"Unassigned" even though the API and ui-spec.md both call for a real per-staff-member picker, and there was no endpoint that could supply that roster (/api/admin/users is Administrator-only). (3) categoryId/ownerId/page each hand-rolled /^d+\$/ validation instead of reusing parseStrictId, and page had no upper bound the way pageSize did, so an absurd page value could reach Prisma as a huge skip and surface as an unhandled 500. (4) the new screen re-implemented MyTickets.tsx's search debounce, categories fetch, and fetch/loading/error shape wholesale rather than sharing it,

and had already drifted (missing `parseApiError`). (5) a stale page with zero rows on it (e.g. after ownership churn) rendered fully blank with no Prev/Next to recover. (6) sortable column headers only existed on the desktop table, not the tablet layout. (7) the response included description and the requester's email though the UI never rendered them. (8) the staff-tickets query building duplicated ``GET /api/tickets``'s pagination/count/findMany shape independently.

Author Response (@vienggg): All eight addressed on the same branch.

(1) `handleOpen` now opens a read-only detail modal populated from the already-fetched queue row — deliberately not I-7's full staff detail screen (ownership panel, status transitions, internal notes; that's issue #56, not yet started, with its own undocumented-until-then ``GET /api/staff/tickets/:id``). Added a row-click → modal test. (2) Added `GET /api/staff/members`` (IT_STAFF/ADMINISTRATOR only, active roster, [{id, name}]), documented in `api-spec.md` §4, and wired the picker to it. (3) `categoryId/ownerId` now reuse `parseStrictId`; page is capped at 100000 with the same 400 shape as every other invalid param; added a huge-page test. (4) Extracted the debounce, categories fetch, and generic paginated-fetch/loading/error state machine into `client/src/hooks/usePaginatedFetch.ts`, shared by both `MyTickets.tsx` and `StaffTicketQueue.tsx`, fixing the `parseApiError` drift. (5) Pagination controls now render whenever `pagination.total > 0` regardless of the current page's row count, and a stale out-of-range page auto-clamps back instead of rendering blank. (6) The tablet table gained the same sortable-header affordance as the desktop table. (7) Dropped the unused `requesterEmail` field; kept description and `requesterName` since the new modal renders both. (8) Extracted `fetchPaginatedTickets` as a shared pagination/count/findMany core for both `GET /api/tickets` and `GET /api/staff/tickets`, matching the `fetchAuthorizedTicketOr404` core-plus-thin-call-sites shape from the last two reviews. 103 server tests (+4 new) and 27 client tests (+2 new) pass.

PR #68: IT Staff Ticket Detail — Changes Requested (@projectnewy, 2026-09-18)

Reviewer Feedback: Ten findings, two blocking. Also called out several things done well: the status-transition matrix matched §6.5 exactly, the `SAFE_REQUESTER_SELECT passwordHash` fix (from this same PR) was checked against every requester: include and found complete, ownership assignment correctly validated the live active-staff roster, and Internal

Notes' 403 masking correctly ran the role check before the ticket lookup. Blocking: (1) GET /api/staff/tickets/:id's permittedStatusTransitions did not apply the same BR-17 filter (IN_PROGRESS blocked while unassigned) that PATCH /status separately enforced — reproducible in the PR's own curl evidence (ticket 232, unassigned, yet permittedStatusTransitions included IN_PROGRESS) — so the client's Status control could offer a choice guaranteed to 409. (2) the evidence transcript (artifacts/lab-03/curl-transcripts-i7.txt) committed a real bcrypt hash for the regression-suite account, permanently in git history even after the runtime leak was fixed. Non-blocking: (3) comments/docs/a test title inaccurately claimed the I-6 read-only modal "remains available" via onOpenTicket after it had actually been deleted; (4) owner/IT-Priority/status PATCH handlers wrote then re-fetched the ticket with a second query instead of using update()'s own include; (5) the Public Comments panel was copy-pasted into StaffTicketDetail.tsx instead of shared, and had already drifted (always showing the role badge, unlike the Requester-side suppression for REQUESTER authors); (6) formatDate was reimplemented locally instead of reusing the shared one, producing a different date format; (7) GET /api/staff/members was fetched independently by both the Queue and Detail screens; (8) --color-internal-note-bg didn't match the spec's documented value; (9) the three save handlers triplicated the same boilerplate; (10) the { id, name } owner projection was repeated ad hoc instead of a named constant like SAFE_REQUESTER_SELECT.

Author Response (@vienggg): All ten addressed. (1) Extracted getPermittedTransitionsForTicket(status, ownerId) in statusTransitions.ts as the single shared BR-17 filter, used by both GET's serializer and PATCH /status's 409 handling. (2) Amended and force-pushed the original commit with the hash redacted, removing it from the branch's own history. (3) Corrected the "remains available" wording in all three places the reviewer named. (4) The three PATCH handlers now pass their include shape directly to update(). (5) Extracted a shared PublicCommentsPanel, preserving the exact role-badge-suppression behavior from the original Requester-side component. (6) Switched to the shared formatDate. (7) Extracted useStaffMembers() mirroring the existing useCategoryOptions pattern. (8) Corrected the CSS variable to the spec's documented #FDF4E7. (9)

Extracted useSavingAction() for the shared save/error/success flow.

(10) Added a named STAFF_OWNER_SELECT constant. 218 server tests (+5 new) and 39 client tests pass.

Follow-up (@projectnewy, same day): *Verified all nine other fixes directly against the branch and confirmed each. Flagged that (2)'s verification claim overstated what was actually achieved: force-push only moves the branch ref, it doesn't garbage-collect the orphaned commit, and the old commit (cab265d) is still fetchable by exact SHA from GitHub — confirmed with `git fetch`, the GitHub API, and `git show cab265d...`, which all still return the real hash. Since this is a seed/regression-fixture credential (the plaintext, RegressionTest789 for this fixture, is already documented in `server/tests/helpers/testAuth.ts`) rather than a live secret, not re-blocking on it — but asked for the claim to be corrected rather than left overstated.*

Author Response (@vienggg): *Agreed and corrected. Force-push removes a commit from a branch's reachable history, which is what a reviewer or grader diffing the branch will see, but does not purge the underlying git object from GitHub's storage — the older SHA remains fetchable directly, and is now doubly discoverable since it's named in this very log. The practical exposure is low (a bcrypt hash for a fixture account whose plaintext password is already committed in source, not a production credential), and a true purge would require GitHub Support intervention, which is out of scope here. Recording the accurate state rather than the overstated one: ****the hash is off the branch's reachable history but not fully purged from GitHub's object storage.*****

PR #69: Administrator User Management — Changes Requested (@projectnewy, 2026-09-18)

Reviewer Feedback: *Nine findings, one blocking. Also confirmed SAFE_ADMIN_USER_SELECT was correctly applied on every response with no full-row leak anywhere, password hashing/mustChangePassword correctly reused the existing helpers, requireRole(ADMINISTRATOR) correctly excluded IT_STAFF on both server and client, and BR-27's self-block had no id-comparison bug. Blocking: (1) BR-28's "last active Administrator" check had a genuine TOCTOU race — the count-then-write was two separate non-transactional statements with no lock, so two concurrent PATCHes deactivating each other of exactly two remaining active Administrators could each read "1 other active admin" before either write committed and both succeed, leaving zero active Administrators, exactly what the rule exists to prevent. Non-blocking: (2) the Part 7 evidence transcript's*

Scenario 4 (IT Staff admin users) still showed the old 404 with a note promising re-capture "once I-8's routes exist" — which was now true; (3) api-spec.md's status-code summary table said 409 for the last-Administrator rule while the implementation and detailed section both used 403; (4) the duplicate-email check ran before the BR-27 self-modification check, so a self-deactivation attempt that also collided on email returned 409 DUPLICATE_EMAIL instead of 403 SELF_MODIFICATION_BLOCKED; (5) the app-level email-uniqueness pre-check raced the DB's unique constraint, and the losing concurrent request's Prisma P2002 fell into the generic catch as an unhandled 500 instead of 409; (6) BR-27/BR-28 were hand-rolled entirely inline with no extracted reusable function; (7) Create User and Edit User were two fully separate modals duplicating ~90% of the same form fields; (8) a locally reimplemented parseApiErrorDetailed duplicated the already-imported parseApiError; (9) no client test exercised RequireRole redirecting an IT_STAFF/Requester away from /admin/users.

Author Response (@vienggg): All nine addressed. (1) Extracted checkAdminSafetyRules(tx, ...) and now run the BR-27/BR-28 checks, the duplicate-email check, and the write inside one transaction, with an explicit SELECT ... FOR UPDATE lock on the active-Administrator row set taken before counting — this is what actually closes the race (plain \$transaction at READ COMMITTED does not), since a second transaction's lock request blocks until the first commits, then re-reads the now-current state. Considered and rejected Serializable isolation (pushes a retry loop onto every caller for a guarantee a small explicit lock gives more cheaply) and the resolution-signal route's atomic-UPDATE-with-WHERE pattern (only works when the checked condition lives on the row being updated itself, not on other rows — BR-28's condition is about other active Administrators). Added a real concurrency test: two Promise.all'd PATCHes against exactly two active Administrators, asserting exactly one succeeds and at least one stays active. (2) Re-captured Scenario 4 — a real 403 now. (3) Corrected the status-code table to 403. (4) Reordered the checks so BR-27 runs first. (5) Both POST and PATCH now catch P2002 explicitly and return 409; added a concurrency test for this too. (6) checkAdminSafetyRules is a named, reusable function. (7) Extracted a single parameterized UserFormModal for both Create and Edit. (8) Removed the duplicated

*function; parseApiError is now a thin wrapper over a new
parseApiErrorDetail that also exposes error.code. (9) Added a test
asserting RequireRole redirects IT_STAFF/Requester away from
/admin/users. 251 server tests (+3 new) and 52 client tests (+2 new)
pass.*

PR #70: E2E specs, full screenshot manifest, visual inspection — Changes Requested (@projectnewy, 2026-09-18)

Reviewer Feedback: *Six findings, one blocking. Opened by noting this PR was "a real step up in rigor" from the PR #68 incident — the three honestly-unchecked checklist items and the ai-use.md process-deviation admission were checked against the actual code and both held up exactly as described, and the login() helper's ARIA-role fix was confirmed as a genuine fix rather than a workaround. Blocking: (1) every new spec authenticates as a regression-suite-* fixture account that is only ever created as a lazy side effect of the server's own vitest suite touching testAuth.ts — absent from seed.ts, with no globalSetup in playwright.config.ts either — so the "13/13 passing" claim was not reproducible from a genuinely fresh database; it only worked because the local dev DB had already accumulated those rows from a different test suite. Worth fixing: (2) the Claim-ticket step's isVisible().catch(() => false) guard meant a future regression hiding the Claim button entirely would report green instead of failing, since the following assertion only checked the button was gone, not that claiming actually happened; (3) shoot(..., "all") left the page stuck at mobile viewport afterward, worked around with three scattered ad hoc resets across two spec files while a third spec never got the same fix; (4) a checked-off checklist item described a UI state (Owner as "static text" vs. a select) that doesn't exist in the actual component. Minor: (5) a checked-off item claimed more than its backing test verified (that status badges are drawn from a declared 7-color scale, not just that they differ from priority badges); (6) the forbidden/not-found checklist item was only tested for two forbidden scenarios, never a genuine not-found ticket ID.*

Author Response (@vienggg): *All six addressed. (1) Added e2e/lab-03/global-setup.ts, wired via playwright.config.ts's globalSetup, running the same ensureRegression*() upserts directly before any spec, independent of any other suite ever having run — required moving testAuth.ts's app import to a lazy dynamic import*

since `app.ts's import.meta.url` isn't valid under Playwright's module resolution for this repo. Verified for real by corrupting the three fixture rows via Prisma and re-running the suite to confirm global setup repairs them before the first login. (2) The Claim step now asserts the button is visible before clicking and asserts the owner value actually changed afterward. (3) Fixed the viewport-stickiness once in `shoot()` itself (captures and restores the pre-call viewport), removed the three ad hoc resets. (4) Corrected the checklist wording — Owner is always one `<select>` with "Unassigned" as one of its own options; left honestly unchecked rather than checked against a state that doesn't exist. (5) Narrowed the claim to match what's actually tested, and flagged the underlying gap (the 7-color scale isn't wired into any CSS yet) as a separate follow-up rather than fixing it here or leaving the checkmark inflated. (6) Added a genuine not-found-ticket test — `StaffTicketDetail.tsx` already handled the case correctly; only the test coverage was missing. 14/14 Playwright tests pass (13 original + 1 new).

PR #71: Release integration — Changes Requested (@projectnewy, 2026-10-04 Bangkok time)

Process correction: Commit `047b5bf` (quality and accessibility audit)

was pushed directly to `lab3-staging` after PR #70 merged. It changed 22 files without a feature PR, contrary to the sprint's GitHub Flow rule.

This is a real workflow deviation; the release PR is the first PR where those changes received peer review. Recording it here does not make the direct push retroactively compliant. The release remains open while the requested corrections are prepared on a separate feature branch.

Reviewer feedback: Four blocking findings: the direct-to-staging commit had not been recorded; the Staff Queue showed old, clickable rows next to an error or during a new fetch; two checked UI-spec assertions claimed evidence the tests did not supply; and the Administrator staff ticket authorization wording changed without a recorded decision. The review also identified tablet sizing/status clipping, incomplete status badge coverage, missing focus and keyboard tests, incomplete traceability, fragile or stateful E2E checks, an unrelated seed-upsert change, and test users visible in screenshots. The full review is preserved on PR #71.

Authorization decision: The pre-audit stakeholder paragraph said an Administrator lacked IT Staff Ticket permissions by role alone, while the authorization matrix already marked those operations as allowed for

Administrators. The API specification and `requireRole(IT_STAFF, ADMINISTRATOR)`` routes also allowed them. The audit made the stakeholder wording match the existing explicit matrix: in this Lab 3 project, Administrators may perform the listed staff ticket operations because the matrix grants them, not because every Administrator inherently inherits all IT Staff rights. This is a clarification of the existing implemented rule, not a new permission introduced at release time. It should have been reviewed in a feature PR before reaching staging.

Author response (reviewed in PR #72): The Staff Queue now clears its row actions during reload/failure while keeping sortable headers mounted so keyboard focus survives a sort; UI-03g covers the loading/error regression. The role checklist now has computed-color assertions for all three roles, and the Owner item describes only the static-label versus enabled-select distinction that its test proves. The tablet table no longer has a forced 1050px minimum; long status text wraps within its badge, with a 992px browser assertion. Requester screens now share TicketStatusBadge, including legacy In_Progress, and the component test covers every status plus fallback values. Attachment removal restores focus after the detail reload; its browser test asserts that result. The test record now traces the visual checks, queue failure case, badge variants, and seed behavior. The focus audit requires the status selector and reports unlisted Tab stops other than Chromium's document-body boundary; the Requester detail audit opens a freshly created ticket by its number. Sort assertions use Playwright's retrying locator checks. The user-list screenshots show a seeded staff account through visible role/search filters, avoiding accumulated test accounts.

Seed decision and remaining scope: The Requester seed upsert's empty update was intentional: a seed rerun should not undo a person's edited name, department, activation, role, or password. The create path still sets the forced initial password. This change was included in the audit commit without being called out and had no dedicated automated test. Navbar/RoleHome behavior is covered by the browser role-navigation tests; separate unit tests and extraction of the two modal focus traps remain possible follow-ups, not claims of coverage in this release review.

Outcome: @projectnewy approved PR #72 at commit ab7495e and merged it into lab3-staging as 9a98cb5 on 2026-10-05 01:00 ICT. The same reviewer then approved the updated release head 9a98cb5 and merged PR #71 into

main as e48d2c8 on 2026-10-05 01:01 ICT. Issue #59 closed automatically.

The release tag lab3-release was subsequently created at e48d2c8.

This review records the earlier direct-to-staging deviation; it does not retroactively turn that push into a feature PR.

3. Reviewer Availability Agreement

@NinjoMUDA and the author coordinated directly (outside this log) that PR review would continue alongside Lab 3 the same way it did for Lab 1 and Lab 2. The recorded GitHub reviews on PRs #61–#72 were submitted by @projectnewy; the relationship between that account and the earlier @NinjoMUDA agreement has not been independently verified, so this log uses the actual reviewing account on each PR entry. Eleven feature/docs branches are expected to move through Backlog → Specified → Started → PR Review → Fixing → Done, one active Issue at a time, with the author never merging their own PR.

Answer Part 2: Spec DD

The engineering contract was merged before implementation PRs. All timestamps below are UTC, taken from the merged PR records.

- Milestone: Spec PR #62 | Merge time (UTC): 2026-09-16 10:48:21
Evidence: [PR #62](#)
- Milestone: Auth PR #64 | Merge time (UTC): 2026-09-16 11:49:11
Evidence: [PR #64](#)
- Milestone: Staff Queue PR #67 | Merge time (UTC): 2026-09-17 10:24:02
Evidence: [PR #67](#)
- Milestone: Staff Detail PR #68 | Merge time (UTC): 2026-09-18 08:26:46
Evidence: [PR #68](#)
- Milestone: Admin PR #69 | Merge time (UTC): 2026-09-18 09:18:00
Evidence: [PR #69](#)

Platform Solutions Resources Open Source Enterprise Pricing

vienggg / toktickit Public

Notifications Fork 0 Star 0

Code Issues 1 Pull requests Actions Projects Security and quality Insights

docs(lab3): Sprint 3 engineering contract #62

Merged projectnewy merged 3 commits into lab3-staging from docs/lab3-spec-and-test-plan 3 weeks ago

Conversation 3 Commits 3 Checks 0 Files changed 22

vienggg commented 3 weeks ago • edited

Closes #49

Writes the Sprint 3 engineering contract before any implementation code, per the handout's anti-backfilling requirement (Part 2). Depends on #61 (Phase 0 infra) merging first.

Deliverables

- docs/lab-03/specification.md : 26 FRs, 32 BRs, authorization matrix, 8x8 status transition matrix, data model/migration strategy, 18 ACs, Definition of Done, documented architectural decisions
- docs/lab-03/api-spec.md : full REST contract for auth, requester, staff, and admin endpoints
- docs/lab-03/ui-spec.md : extends Lab 2 Zen Green tokens with role/status badges and the new/extended screens
- docs/lab-03/tests.md : 27 server + 9 client + 4 E2E planned tests with AC traceability, plus a correction to Lab 2's 'Playwright 34/34' record and the pre-migration regression baseline
- docs/lab-03/reviewer.md , docs/lab-03/ai-use.md : scaffolded as append-on-every-merge logs
- docs/lab-03/sprint-plan.md : the working execution plan (not a graded artifact)

Reviewers

projectnewy

Assignees

No one assigned

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these

Figure 2.1: Merged specification PR #62 header, preceding the implementation PRs.

Specification source: specification.md. The supporting api-spec.md is rendered next.

Rendered document: docs/lab-03/specification.md

Lab 3 Sprint Engineering Specification — TokTickIT Users, Roles, IT Staff Ticketing, and Admin Screens

1. Sprint Goal

Replace the Lab 2 Development Requester selector with real, session-based authentication, and deliver server-enforced role-based authorization for three roles — Requester, IT Staff, and Administrator. This sprint adds a first-login mandatory password change, a professional IT Staff Ticket Queue and operational Ticket Detail (ownership, IT Priority, an 8-state status workflow, Public Comments, and Internal Notes), a minimalist Administrator User Management screen, and continued regression-safe operation of every Lab 2 Requester function under the authenticated identity.

2. Stakeholder Request Interpretation

The Development Requester selector was a useful stand-in during Lab 2 but the system now needs real users. Every Requester ticket operation must be driven by an authenticated identity rather than a client-supplied identifier. IT Staff need a shared queue to find and triage work, claim or reassign ownership, set an internal IT Priority independent of what the Requester asked for, and move a Ticket through a defined status lifecycle while communicating with the Requester through Public Comments and privately through Internal Notes. Administrators need a deliberately minimal screen to create accounts, assign exactly one role, edit basic details, activate or deactivate accounts, and issue a new initial password — never to delete a user. In this sprint, the explicit authorization matrix also grants Administrators the listed staff ticket operations; that is a project-specific authorization, not an automatic privilege of the role. Every protected action must be enforced by the backend; a hidden or disabled button is feedback, not a security control.

3. Scope

Included Work

- Authentication: Email + password login, logout, current-user retrieval, and a mandatory first-login password change that blocks all other application use until satisfied.
- Role-Based Authorization: Three roles (`REQUESTER`, `IT_STAFF`, `ADMINISTRATOR`), each with server-enforced route access; role-specific client navigation that never exposes destinations a role cannot use.
- Identity Migration: Evolution of the Lab 2 `RequesterUser` model into the authenticated `User` model without moving any existing row or breaking any existing `Ticket.requesterId` foreign key; removal of the Development Requester selector and its client-side context.
- Requester Regression: All Lab 2 Ticket and Attachment functions (create, list, search/filter/sort/pagination, detail, edit, attachment upload/soft-removal/download) continued under the authenticated Requester identity, with ownership derived from the session, never from client input.
- Requester Communication: Public Comments on a Requester's own Ticket, and a "Problem Appears Resolved" signal that flags the Ticket without changing its status.
- IT Staff Ticket Queue: Search, filters, sorting, and pagination over all Tickets, with clear ownership and status/priority indicators.
- IT Staff Ticket Detail: Claim, assign, or reassign ownership; set IT Priority; move status through a defined transition matrix; post Public Comments; record Internal Notes; continued access to Lab 2 Attachments.
- Administrator User Management: A single minimalist screen — list with search and optional role filter, create a user with one role and an initial password, edit name/email/role/activation state, set a new initial password, and the three Administrator safety rules (no duplicate email, no self-deactivation, no removing the last active Administrator).
- Zen Green UI Continuity: All new screens reuse the existing Zen Green design tokens, form conventions, badges, and responsive rules established in Lab 2.

Explicitly Excluded Work

- Email invitations, password-reset email, multi-factor authentication, social login, and single sign-on.

- Self-registration or Requester-created accounts.
 - Actions Taken by IT Staff (deferred to Lab 4, along with any rule blocking resolution while Actions Taken remain incomplete).
 - Formal SLA calculation, escalation rules, and notification services.
 - Dashboards and KPI analytics beyond simple queue counts.
 - Multi-tenant organizations, departments as a managed concept, and customer administration.
 - Multiple roles assigned to one user.
 - User deletion, bulk user operations, user import/export, and account-history screens.
 - Department, organization, profile-photo, and other extended user-profile management.
 - Email delivery of initial passwords or reset links.
 - Account unlocking, administrator-approval workflows, and advanced identity-management functions.
 - Mandatory pagination, multi-column sorting, and multiple simultaneous filters on the Administrator user list.
 - Production-grade deployment or cloud infrastructure changes.
-

4. Functional Requirements

Authentication (FR-01 – FR-06)

- FR-01: The system shall authenticate a user by email and password and establish a session on success.
- FR-02: The system shall reject authentication for an inactive account without granting a session.
- FR-03: The system shall expose a current-user endpoint returning identity, role, and password-change state, and shall never return the password hash.
- FR-04: The system shall block access to all application routes except the change-password flow while `mustChangePassword` is true.
- FR-05: The system shall allow a user to change their own password, clearing `mustChangePassword` on success.
- FR-06: The system shall allow a user to log out, invalidating the client-held session token.

Authorization (FR-07 – FR-09)

- FR-07: Every protected server route shall verify the caller's authenticated identity and role before performing the operation.
- FR-08: Requester-scoped operations shall determine ownership solely from the authenticated identity, never from a client-supplied identifier.
- FR-09: The client shall render only the navigation and actions permitted for the current user's role; the server shall independently enforce the same restriction regardless of what the client renders.

Requester Regression and Communication (FR-10 – FR-13)

- FR-10: The system shall continue to support Requester Ticket creation, listing, searching, filtering, sorting, pagination, detail viewing, editing, and Attachment upload/soft-removal/download exactly as delivered in Lab 2, scoped to the authenticated Requester.
- FR-11: The system shall allow a Requester to post a Public Comment on a Ticket they own.
- FR-12: The system shall allow a Requester to indicate that a problem appears resolved without changing the Ticket's status.

- FR-13: The system shall prevent a Requester from reading Internal Notes or performing any IT Staff or Administrator operation.

IT Staff Operations (FR-14 – FR-19)

- FR-14: The system shall provide a Ticket Queue to IT Staff and Administrators showing all Tickets with search, filters, sorting, and pagination.
- FR-15: The system shall allow an IT Staff or Administrator to claim an unassigned Ticket or reassign an assigned one to any active IT Staff or Administrator user.
- FR-16: The system shall allow an IT Staff or Administrator to set IT Priority independently of Requested Priority.
- FR-17: The system shall allow an IT Staff or Administrator to change Ticket status only along the permitted transition matrix (§5.5).
- FR-18: The system shall allow an IT Staff or Administrator to post Public Comments and Internal Notes on any Ticket.
- FR-19: The system shall reject a status change that does not follow the permitted transition matrix, returning the currently permitted set.

Administrator User Management (FR-20 – FR-26)

- FR-20: The system shall provide a user list to Administrators with search by name or email and optional role filtering.
- FR-21: The system shall allow an Administrator to create a user with a name, unique email, one role, an activation state, and an initial password.
- FR-22: The system shall allow an Administrator to edit a user's name, email, role, and activation state.
- FR-23: The system shall allow an Administrator to set a new initial password for a user, forcing a password change at that user's next login.
- FR-24: The system shall reject account creation or edits that would produce a duplicate email address or an invalid role value.
- FR-25: The system shall prevent an Administrator from deactivating or demoting their own account.
- FR-26: The system shall prevent an operation that would leave zero active Administrator accounts.

5. Business Rules

Authentication and Session (BR-01 – BR-08)

- BR-01: Only an active user with valid credentials may authenticate.
- BR-02: A user marked as requiring a password change cannot enter the normal application until a new valid password is saved.
- BR-03: The authenticated user identity, not a `requesterId` supplied by the client, determines ownership of Requester operations.
- BR-04: Public Comments are visible to the Requester, IT Staff, and Administrator. Internal Notes are visible only to IT Staff and Administrator.
- BR-05: A Requester may indicate that the problem appears resolved, but cannot formally set the Ticket to Resolved or Closed.
- BR-06: An invalid email/password combination always returns an identical generic 401 response, regardless of whether the email exists, to avoid revealing account existence.

- BR-07: A correct password against an inactive account returns 403 with a deactivation message — the account's existence has already been proven by the correct credential, so this does not leak new information.
- BR-08: Logout is idempotent and always succeeds; the session cookie is cleared and expires no later than 2 hours after issuance regardless of activity.

Password Rules (BR-09 – BR-12)

- BR-09: A password must be at least 8 characters and contain at least one letter and one digit.
- BR-10: A new password set during a mandatory change must differ from the initial password.
- BR-11: A password change requires the new password and its confirmation to match exactly.
- BR-12: Passwords are never stored or transmitted in plaintext; only a bcrypt hash is persisted.

Ownership, Assignment, and Priority (BR-13 – BR-17)

- BR-13: A Ticket may have at most one primary Ticket Owner, who must be an active IT Staff or Administrator user.
- BR-14: A Ticket may initially be unassigned; claiming sets the owner to the acting IT Staff/Administrator; reassignment may set the owner to any other active IT Staff/Administrator.
- BR-15: Requested Priority remains the value submitted by the Requester and is never edited after creation.
- BR-16: IT Priority initially copies Requested Priority at Ticket creation and may thereafter be changed only by IT Staff or Administrator.
- BR-17: A Ticket may not enter `IN_PROGRESS` while unassigned.

Status Workflow (BR-18 – BR-20)

- BR-18: The required Ticket statuses are `NEW`, `OPEN`, `IN_PROGRESS`, `WAITING_FOR_REQUESTER`, `RESOLVED`, `CLOSED`, `REOPENED`, and `CANCELLED`.
- BR-19: A status change is permitted only along the transition matrix in §5.5; any other requested transition is rejected with HTTP 409 and the list of currently permitted destinations.
- BR-20: Only IT Staff and Administrator may change Ticket status; a Requester can set no status at all.

Comments and Notes (BR-21 – BR-24)

- BR-21: Public Comments and Internal Notes are append-only in Lab 3; editing and deletion are excluded.
- BR-22: Each Comment or Note records its author and creation time from the backend; the client cannot set either value.
- BR-23: Empty or whitespace-only content is rejected; content is limited to 1–2000 characters and is rendered as plain text, never as HTML.
- BR-24: A request for Internal Notes made by a Requester is rejected with HTTP 403 and returns no note content of any kind.

Administrator Safety (BR-25 – BR-29)

- BR-25: Every user has exactly one role at a time: `REQUESTER`, `IT_STAFF`, or `ADMINISTRATOR`.
- BR-26: An email address must be unique across all users (case-insensitive comparison).
- BR-27: An Administrator cannot deactivate or change the role of their own account.
- BR-28: The system shall reject any update that would leave zero active Administrator accounts.
- BR-29: Deactivation is used instead of deletion; no user account is ever removed.

Migration and Regression (BR-30 – BR-32)

- BR-30: Every RequesterUser row from Lab 2 is evolved into a User row with `role = REQUESTER`, a documented local-development initial password, and `mustChangePassword = true`; no row is deleted or recreated, and every existing `Ticket.requesterId` continues to reference the same row.
 - BR-31: No Lab 1 or Lab 2 automated test may regress as a result of the Lab 3 identity migration; ownership-dependent tests are updated to authenticate rather than to pass a raw identifier.
 - BR-32: A cross-requester request for another Requester's Ticket returns HTTP 404 (not 403), so the response does not reveal whether the Ticket exists; this is a deliberate exception to using 403 for authorization failures, reserved for resource-existence masking only.
-

6. Authorization Matrix

Operation: Login / logout / current user / change password | Requester: (own account)

IT Staff: (own account)

Administrator: (own account)

Operation: Create / list / view own Tickets | Requester:

IT Staff: —

Administrator: —

Operation: Edit own Ticket, manage own Attachments | Requester:

IT Staff: —

Administrator: —

Operation: Post Public Comment on own/any Ticket | Requester: (own only)

IT Staff: (any)

Administrator: (any)

Operation: Indicate "Problem Appears Resolved" | Requester: (own only)

IT Staff: —

Administrator: —

Operation: View/read Internal Notes | Requester: (403, no content)

IT Staff:

Administrator:

Operation: Create Internal Note | Requester:

IT Staff:

Administrator:

Operation: View IT Staff Ticket Queue | Requester:

IT Staff:

Administrator:

Operation: Claim / reassign Ticket ownership | Requester:

IT Staff:

Administrator:

Operation: Set IT Priority | Requester:

IT Staff:

Administrator:

Operation: Change Ticket status | Requester:

IT Staff: (per §5.5)

Administrator: (per §5.5)

Operation: View/search/filter User Management list | Requester:

IT Staff:

Administrator:

Operation: Create / edit user, set initial password | Requester:

IT Staff:

Administrator:

Operation: Activate / deactivate a user | Requester:

IT Staff:

Administrator: (not self; not last active Admin)

For Lab 3, the matrix is the sole source of truth for what each role may do. It explicitly authorizes Administrators for the staff ticket operations marked above, in addition to Administrator User Management. Hiding a client control is a usability aid, never a substitute for the server checks in this table.

6.5. Status Transition Matrix

From \ To: NEW | NEW: —

OPEN:

IN_PROGRESS:

WAITING_FOR_REQUESTER: —

RESOLVED: —

CLOSED: —

REOPENED: —

CANCELLED:

From \ To: OPEN | NEW: —

OPEN: —

IN_PROGRESS:

WAITING_FOR_REQUESTER:

RESOLVED:

CLOSED: —

REOPENED: —

CANCELLED:

From \ To: IN_PROGRESS | NEW: —

OPEN: —

IN_PROGRESS: —

WAITING_FOR_REQUESTER:

RESOLVED:

CLOSED: —

REOPENED: —

CANCELLED:

From \ To: WAITING_FOR_REQUESTER | NEW: —

OPEN: —

IN_PROGRESS:

WAITING_FOR_REQUESTER: —

RESOLVED:

CLOSED: —

REOPENED: —

CANCELLED:

From \ To: RESOLVED | NEW: —
 OPEN: —
 IN_PROGRESS: —
 WAITING_FOR_REQUESTER: —
 RESOLVED: —
 CLOSED:
 REOPENED:
 CANCELLED: —

From \ To: CLOSED | NEW: —
 OPEN: —
 IN_PROGRESS: —
 WAITING_FOR_REQUESTER: —
 RESOLVED: —
 CLOSED: —
 REOPENED:
 CANCELLED: —

From \ To: REOPENED | NEW: —
 OPEN: —
 IN_PROGRESS:
 WAITING_FOR_REQUESTER:
 RESOLVED:
 CLOSED: —
 REOPENED: —
 CANCELLED:

From \ To: CANCELLED | NEW: —
 OPEN: —
 IN_PROGRESS: —
 WAITING_FOR_REQUESTER: —
 RESOLVED: —
 CLOSED: —
 REOPENED: —
 CANCELLED: —

CANCELLED is terminal. A Ticket cannot enter IN_PROGRESS while ownerId is null (BR-17). Any cell not marked returns HTTP 409 with the row's permitted destinations.

7. UI Specification Summary

See `ui-spec.md` for the full screen-by-screen specification. In summary: a Login screen and a mandatory Change Password screen gate entry to the application; the authenticated shell replaces the Lab 2 Navbar's Development Requester pill with the current user's name, role badge, and Logout; role-specific navigation shows only permitted destinations; the IT Staff Ticket Queue and Ticket Detail extend the Lab 2 Ticket Detail with ownership, priority, status, and the Public Comment / Internal Note panels rendered as visually distinct blocks; the Administrator screen is a single list-with-modal-forms pattern consistent with Lab 2's card and form conventions. All screens remain usable at 1280px, 768px, and 375px.

8. Data Changes

- **User** (Prisma model, `@@map("RequesterUser")` to preserve the existing physical table and avoid any row movement): adds `role` (enum `Role`), `passwordHash`, `mustChangePassword`, `isActive` (already present), `lastLoginAt`. Retains `name`, `email` (unique), `department`.
- **Ticket**: adds `itPriority` (enum `Priority`, backfilled from the existing `priority` column, renamed at the Prisma-field level to `requestedPriority` via `@map("priority")` — no column rename at the database level), `ownerId` (nullable FK to `User`), `requesterResolvedAt` (nullable timestamp). `status` and `priority` are converted from `String` to native Prisma enums (`TicketStatus`, `Priority`) via a hand-verified migration (see below).
- **PublicComment** and **InternalNote** (new, separate tables): `id`, `ticketId` (FK, cascade delete), `authorId` (FK to `User`), `body` (1–2000 chars), `createdAt`.
- **Enums**: `Role` (`REQUESTER`, `IT_STAFF`, `ADMINISTRATOR`), `Priority` (`LOW`, `MEDIUM`, `HIGH`, `URGENT`), `TicketStatus` (the 8 values in BR-18).
- **Indexes**: `User(role)`, `User(isActive)`, `Ticket(ownerId)`, `Ticket(itPriority)`, `Ticket(updatedAt)`, `PublicComment(ticketId, createdAt)`, `InternalNote(ticketId, createdAt)`.

Migration Strategy

Migrations are managed with `prisma migrate` from a `0_init` baseline of the existing Lab 2 schema (verified to contain no destructive statements before being marked applied). Because Prisma's generated SQL for a `String` → `native enum` conversion issues a destructive `DROP COLUMN/ADD COLUMN` pair, every enum-introducing migration is generated with `--create-only`, hand-edited to use `CREATE TYPE + ALTER COLUMN ... TYPE ... USING` casts that preserve existing values, and rehearsed against a restored `pg_dump` backup before being applied to the working database. Migration sequence: `0_init` (baseline) `1_add_enums_and_backfill` `2_add_user_auth_fields` `3_add_ticket_workflow_fields` `4_add_comments_and_notes`. Regression evidence is a before/after row count and `requesterId` comparison, captured in `tests.md`.

Seed Data

Idempotent (upsert by email): 4 active + 1 inactive Requester (evolved from the 5 existing Lab 2 `RequesterUser` rows); 3 active + 1 inactive IT Staff; 2 active Administrators (to demonstrate both the allowed deactivation case and the last-Administrator block); at least 25 Tickets spanning all 8 statuses, both priority axes, and assigned/unassigned ownership; representative Public Comments and Internal Notes containing no sensitive information. All seeded credentials are for local development only and are documented in `README.md`, never committed as real secrets.

9. API Contract

See `api-spec.md` for the full endpoint-by-endpoint contract, request/response shapes, and status codes.

10. Acceptance Criteria

ID: AC-01 | Criterion: Given an active user with valid credentials, when the user logs in, then the backend establishes authenticated access and returns the permitted user identity and role.

ID: AC-02 | Criterion: Given a user who must change the initial password, when login succeeds, then normal application screens remain unavailable until a valid new password is saved.

ID: AC-03 | Criterion: Given an authenticated Requester, when the client supplies another `requesterId`, then the backend still applies the authenticated identity and does not return another Requester's data.

ID: AC-04 | Criterion: Given a Requester account, when an Internal Note endpoint is requested, then the operation is rejected without exposing note content.

ID: AC-05 | Criterion: Given invalid credentials, when login is attempted, then the response is a generic 401 that does not reveal whether the email exists.

ID: AC-06 | Criterion: Given an inactive account with a correct password, when login is attempted, then the response is 403 with a deactivation message.

ID: AC-07 | Criterion: Given an authenticated session, when logout is called, then the session cookie is cleared and a subsequent protected request returns 401.

ID: AC-08 | Criterion: Given an unassigned Ticket, when IT Staff claims it, then `ownerId` is set to the acting user and the Ticket becomes eligible for `IN_PROGRESS`.

ID: AC-09 | Criterion: Given a Ticket in `NEW`, when IT Staff requests a transition to `RESOLVED`, then the request is rejected with 409 and the permitted destination set is returned.

ID: AC-10 | Criterion: Given a Requester's own Ticket, when the Requester indicates the problem appears resolved, then a flag is set and the status is unchanged.

ID: AC-11 | Criterion: Given a duplicate email on user creation, when an Administrator submits the form, then the request is rejected with 409 and no user is created.

ID: AC-12 | Criterion: Given the only active Administrator, when that Administrator attempts to deactivate their own account, then the request is rejected.

ID: AC-13 | Criterion: Given the only active Administrator, when an attempt is made to deactivate or demote a different user leaving zero active Administrators, then the request is rejected.

ID: AC-14 | Criterion: Given a user with a newly set initial password, when that user next logs in, then they are forced into the change-password flow before reaching the application.

ID: AC-15 | Criterion: Given a logged-out session, when a client attempts to navigate directly to a protected route, then the client redirects to `/login` and the server independently returns 401 for the underlying API call.

ID: AC-16 | Criterion: Given the Requester Ticket Queue-equivalent (My Tickets) after migration, when an evolved Requester logs in, then all Tickets originally owned by their `RequesterUser` row are still visible and correctly attributed.

ID: AC-17 | Criterion: Given a Requester querying another Requester's Ticket by ID, when the request is made, then the response is 404, not 403, and does not confirm the Ticket's existence.

ID: AC-18 | Criterion: Given the IT Staff Ticket Queue, when an invalid query parameter is supplied, then the response is 400 naming the offending field.

11. Definition of Done

- All Functional Requirements (§4) and Business Rules (§5) are implemented and covered by at least one automated test named in `tests.md`.
- The authorization matrix (§6) and status transition matrix (§6.5) are enforced identically on the server regardless of client UI state.
- All 63 pre-existing Lab 1/Lab 2 automated tests pass unmodified in intent (rewritten only to authenticate instead of passing a raw identifier), with zero regression in ticket/attachment behavior.
- The `0_init 4_add_comments_and_notes` migration sequence applies cleanly to a restored copy of the pre-Lab-3 database with zero data loss, verified by matching row counts.
- `docs/lab-03/specification.md`, `api-spec.md`, `ui-spec.md`, and `tests.md` are merged into `lab3-staging` before any implementation Issue (I-2 onward) is merged, with a printed timestamp/PR-merge comparison as evidence.
- Every required screen (Login, Change Password, My Tickets/Create/Detail, Staff Queue, Staff Ticket Detail, Administrator User Management) is usable at 1280px, 768px, and 375px with no horizontal overflow.
- `reviewer.md` and `ai-use.md` are updated at every merged PR, not reconstructed at the end of the sprint.
- The final `main` branch contains all ten feature/docs branches merged through `lab3-staging`, tagged `lab3-release`, with the GitHub Project board showing all Issues in Done.

12. Assumptions and Decisions

- Session mechanism: JWT (HS256) carried in an `httpOnly`, `SameSite=Lax` cookie, 2-hour expiry. Chosen because `httpOnly` eliminates XSS token theft and `SameSite=Lax` covers CSRF without a separate token exchange. Accepted trade-off: a stateless JWT cannot be revoked server-side before expiry; logout clears the cookie client-side and the short expiry bounds the exposure window.
- Password hashing: `bcryptjs` at cost factor 10 — pure JavaScript, avoiding native build tooling in the development environment.
- User identity migration: `RequesterUser` is renamed to `User` at the Prisma-model level only (`@@map("RequesterUser")`), guaranteeing zero row movement and zero risk to existing `Ticket.requesterId` foreign keys.
- Comments vs. Notes: implemented as two separate tables rather than one table with a visibility flag, so a Requester query can never structurally return Internal Note rows.
- Client routing: `react-router-dom` v7 (declarative mode: `BrowserRouter/Routes/Route`, the same API surface as v6) is introduced specifically so that "direct access blocked after logout" (AC-15) is demonstrable via the browser address bar, which was not possible under Lab 2's tab-state navigation. v7 was installed because v6 is no longer npm's published `latest` and is not actively maintained; declarative mode keeps the implementation identical to what a v6-based build would have looked like.
- Requester resolution signal: implemented as a boolean/timestamp flag plus an auto-generated Public Comment, never as a status value, so BR-05 cannot be bypassed by a client sending a status field.
- Error masking exception: 403 is used for role/permission failures throughout; 404 is used only for the single case of a Requester requesting another Requester's own-Ticket resource, per BR-32, to avoid confirming the Ticket's existence. This is documented here so it is not mistaken for an unenforced route.
- Development database port collision (discovered during I-2): this development machine runs two independent Postgres 16 servers both listening on port 5432 — a Docker container (reachable only via `docker exec`) and a real Postgres instance inside a WSL Ubuntu distro (reachable via `localhost:5432` from every host-side tool, since Windows prefers the more specific `127.0.0.1` binding over Docker's `0.0.0.0` one). The Docker container proved to be a stale, unused artifact never touched since initial `docker-compose` setup; the WSL instance is the real database behind all local development and the already-submitted Lab 2 report. `docker-compose.yml`'s `db` service now publishes host port 5433 instead of 5432 to remove the ambiguity; its internal container-to-container traffic is unaffected. The Phase 0 backup and regression baseline in `tests.md` were retaken against the correct (WSL) database after this was found.
- Idempotent seed data: `prisma/seed.ts` was changed from a destructive delete-then-recreate pattern (which would have wiped any ticket created through real app usage on every seed run) to an additive upsert/skip-if-exists pattern, per §5.3's "safe to run repeatedly" requirement. Verified idempotent by running it twice consecutively with identical resulting counts.
- API response compatibility during migration (I-2): the Prisma field rename (`priority requestedPriority`) and the `status/priority` column type change (`String` native enum) are internal to the data layer. The Lab 2 REST API's JSON response shape (`priority`, `status` as Title-Case/underscore strings) is preserved unchanged via a `serializeTicket` mapping in `app.ts`, so the existing Lab 2 client and its 18 automated tests continue to pass without modification. This is a deliberate, temporary compatibility shim; I-4 (Requester regression) is the issue that reworks the API contract and client together.

Rendered document: <docs/lab-03/api-spec.md>

Lab 3 REST API Contract — TokTickIT

All endpoints are prefixed `/api`. Authentication is a JWT carried in an `httpOnly`, `SameSite=Lax` cookie named `toktickit_session` (2-hour expiry). There is no bearer-token header; every authenticated request relies on the browser (or a `curl` cookie jar) sending that cookie automatically.

Conventions

- Content type: `application/json` request and response bodies unless noted.
- Error shape: `{ "error": { "code": string, "message": string } }`. Messages are safe for display and never leak stack traces, ORM errors, or another user's data.

- Status codes:

Code: 400 | Meaning: Validation failure — malformed body or query parameter

Code: 401 | Meaning: No valid session

Code: 403 | Meaning: Authenticated but not permitted for this role/action, including BR-27 self-modification and BR-28 last-Administrator blocks

Code: 404 | Meaning: Resource not found, or deliberately masked (see BR-32)

Code: 409 | Meaning: Conflict — duplicate email, illegal status transition

Code: 500 | Meaning: Unexpected server error — generic message only

1. Authentication

POST `/api/auth/login`

Public. Body: `{ email, password }`.

- 200 `{ user: { id, name, email, role, mustChangePassword } }`, sets the session cookie.
- 401 generic invalid-credentials error (BR-06) — identical whether the email exists or not.
- 403 `{ error: { code: "ACCOUNT_INACTIVE", ... } }` when the password is correct but the account is deactivated (BR-07).

POST `/api/auth/logout`

Requires a session. Clears the cookie. 204. Idempotent — succeeds even if already logged out (BR-08).

GET `/api/auth/me`

Requires a session. 200 `{ id, name, email, role, department, mustChangePassword }`. Never returns `passwordHash`. 401 if no valid session.

POST `/api/auth/change-password`

Requires a session. Body: `{ currentPassword, newPassword, confirmPassword }`.

- 200 clears `mustChangePassword`, returns the refreshed user object.
- 400 password policy violation (BR-09), mismatch (BR-11), or new equals initial password on a forced change (BR-10).

2. Requester Ticket and Attachment APIs (Lab 2 continuation, re-scoped)

All `requesterId` query/body parameters from Lab 2 are removed. Ownership is derived exclusively from the session (BR-03, FR-08).

Method: GET | Path: `/api/tickets`

Notes: Lists only the authenticated Requester's Tickets. Same search/filter/sort/pagination contract as Lab 2.

Method: POST | Path: `/api/tickets`

Notes: Creates a Ticket owned by the authenticated Requester.

Method: GET | Path: `/api/tickets/:id`

Notes: 404 if the Ticket does not belong to the authenticated Requester (BR-32) — not 403.

Method: PATCH | Path: `/api/tickets/:id`

Notes: Edits summary/description/priority before IT triage; 404 if not owned.

Method: POST | Path: `/api/tickets/:id/attachments`

Notes: Now requires authentication and an ownership check (404 if not owned) — Lab 2 only checked the ticket existed, not who owned it.

Method: DELETE | Path: `/api/tickets/:id/attachments/:attId`

Notes: Soft-removal. Correction: Lab 2's version had no ownership check on the parent Ticket at all (only that the attachment belonged to the given ticket ID); this is now closed.

Method: GET | Path: `/api/tickets/:id/attachments/:attId/download`

Notes: New in I-4. Lab 2 never actually had this endpoint — the client linked directly to the static `/uploads/<file>` path, which enforced neither ownership nor removal state despite the Lab 2 report describing 403/410 protection there. This route provides it for real: 404 if the Ticket is not owned, 410 if the attachment is soft-removed, otherwise streams the file.

POST `/api/tickets/:id/resolution-signal`

Requester only, must own the Ticket. No body. 200 sets `requesterResolvedAt` and creates an auto-generated Public Comment. Does not change `status` (BR-05, D-10). 404 if not owned.

3. Public Comments (shared) and Internal Notes (staff-only)

GET `/api/tickets/:id/comments`

Requester (own Ticket only), IT Staff, Administrator. 200 array of { `id`, `ticketId`, `authorId`, `authorName`, `body`, `createdAt` }.

POST `/api/tickets/:id/comments`

Same roles as above. Body: { `body` }, 1–2000 chars, non-blank (BR-23). 201 on success, 400 on validation failure.

GET `/api/tickets/:id/internal-notes`

IT Staff and Administrator only. A Requester request returns 403 with no note data of any kind in the body (AC-04, BR-24).

POST `/api/tickets/:id/internal-notes`

Same restriction as above. Body: { `body` }, same validation as comments.

4. IT Staff Ticket Queue and Operations

GET `/api/staff/tickets`

IT Staff, Administrator only. Query parameters:

Param: `search` | Type: string

Notes: Matches ticket number, summary, description, requester name/email

Param: `status` | Type: enum

Notes: One of the 8 `TicketStatus` values, or `All`

Param: `itPriority` | Type: enum

Notes: LOW/MEDIUM/HIGH/URGENT, or All

Param: `categoryId` | Type: int

Param: `ownerId` | Type: int \

Notes: "unassigned"

Param: `sort` | Type: enum

Notes: `createdAt`, `updatedAt`, `itPriority`, `status`, `ticketNumber`

Param: `order` | Type: enum

Notes: `asc` \

Param: `page` | Type: int

Notes: default 1

Param: `pageSize` | Type: int

Notes: default 10, max 50

Response: { `data`: Ticket[], `pagination`: { `page`, `pageSize`, `total`, `totalPages` } }. An invalid parameter (unknown enum value, non-numeric `page`, `pageSize` > 50) returns 400 naming the offending field. Default ordering is `updatedAt desc`. Added in review of PR #67: `page` is also capped at 100000 (400, naming `page`) — previously only `pageSize` had an upper bound, so an absurdly large `page` value passed validation and produced an oversized `skip` handed straight to Prisma.

GET /api/staff/members

Added in review of PR #67 to support the Owner filter picker on the Ticket Queue screen (I-6) — there was no existing endpoint that lists IT Staff/Administrator users, and `/api/admin/users` below is Administrator-only, which is wrong for this purpose since a regular IT Staff member must also be able to filter the queue by owner. IT Staff, Administrator only. No query parameters. 200 array of { `id`, `name` } for active IT_STAFF/ADMINISTRATOR users, ordered by name. Intentionally minimal — just the roster data a picker needs, not the fuller shape GET `/api/admin/users` returns.

GET /api/staff/tickets/:id

IT Staff, Administrator only. Full operational view including owner, IT Priority, status, comments, and internal notes.

PATCH /api/staff/tickets/:id/owner

Body: { `ownerId`: number | null }. null unassigns. `ownerId` must reference an active IT Staff or Administrator user (BR-13) or 400 is returned.

PATCH /api/staff/tickets/:id/it-priority

Body: { `itPriority` }. IT Staff, Administrator only (BR-16).

PATCH /api/staff/tickets/:id/status

Body: { `status` }. Validated against the transition matrix in `specification.md` §6.5. An illegal transition returns 409 with { `error`: { `code`: "ILLEGAL_TRANSITION", `permitted`: [...] } }. Entering IN_PROGRESS while `ownerId` is null returns 409 (BR-17).

5. Administrator User Management

GET /api/admin/users

Administrator only. Query: `search` (name or email substring), `role` (optional filter). No pagination required by scope. 200 array of { `id`, `name`, `email`, `role`, `isActive` }.

POST /api/admin/users

Body: { name, email, role, isActive, initialPassword }. 201 on success. 409 on duplicate email (case-insensitive, BR-26). 400 on invalid role (BR-24) or missing fields. New user is created with `mustChangePassword: true`.

PATCH /api/admin/users/:id

Body: any of { name, email, role, isActive }. 409 on duplicate email. 403 if the request would deactivate or demote the acting Administrator's own account (BR-27) or leave zero active Administrators (BR-28).

POST /api/admin/users/:id/initial-password

Body: { initialPassword }. Sets a new password hash and `mustChangePassword: true`. 200 on success.

6. Authorization Enforcement Summary

Every route above (except `POST /api/auth/login`) passes through:

- `requireAuth` — 401 if no valid session cookie.
- `requirePasswordChanged` — 403 if `mustChangePassword` is true and the route is not `/api/auth/me`, `/api/auth/change-password`, or `/api/auth/logout`.
- `requireRole([...])` — 403 if the authenticated role is not in the allowed set for that route.
- Resource-level ownership check where applicable (Requester Ticket routes) — 404, per BR-32, rather than 403.

This ordering guarantees that a hidden or disabled client control is never the only thing standing between a user and a forbidden operation.

Answer Part 3: Test DD and Traceability

On release commit e48d2c8, server Vitest passed 251/251 and client Vitest passed 69/69. The first browser run passed 29/30 and exposed the Create User/list-refresh race; the I-11 fix branch then passed 30/30. The final main-branch browser result must be captured after I-11 merges.

Command output: main-server-tests.txt

```
Checkout: detached origin/main at e48d2c8 (PR #71 merge)
Command: cd server && npm test
Exit code: 0
Condensed from the observed terminal output: per-file results and totals are retained;
individual slow-test timing lines are omitted.

> toktickit-server@1.0.0 test
> vitest run

RUN v2.1.9 C:/Users/User/OneDrive/Desktop/softwareengineer/toktickit/server

  tests/lab-02/ticket-number.unit.test.ts (3 tests)
  tests/lab-03/status-transitions.unit.test.ts (77 tests)
  tests/lab-03/migration-regression.api.test.ts (5 tests)
  tests/lab-03/password.unit.test.ts (8 tests)
  tests/lab-01/health.test.ts (1 test)
  tests/lab-01/categories.test.ts (2 tests)
  tests/lab-02/my-tickets.api.test.ts (5 tests)
  tests/lab-01/systems.test.ts (2 tests)
  tests/lab-02/create-ticket.api.test.ts (5 tests)
  tests/lab-02/ticket-detail.api.test.ts (12 tests)
  tests/lab-03/staff-queue.api.test.ts (21 tests)
  tests/lab-03/comments-notes.api.test.ts (23 tests)
  tests/lab-03/auth.api.test.ts (14 tests)
  tests/lab-03/authorization.api.test.ts (16 tests)
  tests/lab-03/staff-ticket-detail.api.test.ts (24 tests)
  tests/lab-03/users-admin.api.test.ts (33 tests)

Test Files  16 passed (16)
   Tests    251 passed (251)
   Start at 01:09:37
   Duration 5.60s
```

Command output: main-client-tests.txt

```
Checkout: detached origin/main at e48d2c8 (PR #71 merge)
Command: cd client && npm test
Exit code: 0
Condensed from the observed terminal output: per-file results and totals are retained;
individual slow-test timing lines are omitted.

> toktickit-client@1.0.0 test
> vitest run

RUN v2.1.9 C:/Users/User/OneDrive/Desktop/softwareengineer/toktickit/client

  tests/lab-03/TicketStatusBadge.test.tsx (14 tests)
  tests/lab-03/ProtectedRoute.test.tsx (3 tests)
  tests/lab-01/App.test.tsx (3 tests)
  tests/lab-03/Login.test.tsx (4 tests)
  tests/lab-03/ChangePassword.test.tsx (3 tests)
  tests/lab-02/CreateTicket.test.tsx (2 tests)
  tests/lab-02/TicketDetail.test.tsx (5 tests)
  tests/lab-02/MyTickets.test.tsx (2 tests)
  tests/lab-03/StaffTicketDetail.test.tsx (11 tests)
  tests/lab-03/UserManagement.test.tsx (10 tests)
  tests/lab-03/StaffTicketQueue.test.tsx (12 tests)

Test Files  11 passed (11)
   Tests    69 passed (69)
   Start at 01:09:37
   Duration 4.57s
```

Command output: `main-e2e-tests.txt`

Final main-branch command output pending.

Traceability source: `tests.md`.

Rendered document: `docs/lab-03/tests.md`

Lab 3 Test DD and Traceability — TokTickIT

This plan is written before implementation, alongside `specification.md`, `api-spec.md`, and `ui-spec.md` (I-I), and is updated in place as each feature Issue lands — never reconstructed after the fact. "Final" status is filled in as each test is written and run; a blank cell means not yet implemented.

Correction to the Lab 2 Test Record

Lab 2's `docs/lab-02/tests.md` and `docs/session_state.md` report "Playwright 34/34 passing" for an end-to-end suite. That suite did not exist inside the repository — the actual script was `lab2/test_all_features_e2e.mjs`, a hand-rolled script using the `playwright` library directly, living outside `toktickit/` entirely, with no `e2e/` folder and no `@playwright/test` runner in the repo at that time. Lab 3 introduces `@playwright/test` properly (see Phase 0 of `docs/lab-03/sprint-plan.md`) and this record is corrected here rather than carried forward silently.

Coverage Levels Required (per handout §10)

Unit · API/Integration · UI Component · UI Style · Responsive · Security/Authorization · Migration/Regression · End-to-End.

Server Tests — `server/tests/lab-03/`

Test ID: UNIT-01 | Type: Unit

Requirement/AC: BR-12

What It Tests: Password hash/verify round-trip

Expected Result: Hash never equals plaintext; verify succeeds only for correct password

Automated Test File: `server/tests/lab-03/password.unit.test.ts`

Final: Pass

Test ID: UNIT-02 | Type: Unit

Requirement/AC: BR-09

What It Tests: Password policy validator

Expected Result: Rejects <8 chars, no letter, or no digit; accepts a compliant password

Automated Test File: `server/tests/lab-03/password.unit.test.ts`

Final: Pass

Test ID: UNIT-03 | Type: Unit

Requirement/AC: BR-19, §6.5

What It Tests: Status transition matrix — all legal edges

Expected Result: Every cell in §6.5 returns `permitted=true`

Automated Test File: `server/tests/lab-03/status-transitions.unit.test.ts`

Final: Pass

Test ID: UNIT-04 | Type: Unit

Requirement/AC: BR-19, §6.5

What It Tests: Status transition matrix — all illegal edges

Expected Result: Every non- cell returns permitted=false with the correct permitted-set

Automated Test File: `server/tests/lab-03/status-transitions.unit.test.ts`

Final: Pass

Test ID: UNIT-05 | Type: Unit

Requirement/AC: BR-17 (added in review of PR #68 — item 1: `getPermittedTransitionsForTicket` extracted so GET's serializer and PATCH /status share one BR-17 filter instead of two independent copies)

What It Tests: `getPermittedTransitionsForTicket` helper

Expected Result: Excludes `IN_PROGRESS` when `ownerId` is null; includes it once owned; leaves other statuses' permitted sets unchanged

Automated Test File: `server/tests/lab-03/status-transitions.unit.test.ts`

Final: Pass

Test ID: API-01 | Type: API

Requirement/AC: AC-01

What It Tests: Valid login

Expected Result: 200, authenticated cookie set, safe user object (no hash)

Automated Test File: `server/tests/lab-03/auth.api.test.ts`

Final: Pass

Test ID: API-02 | Type: API

Requirement/AC: AC-05, BR-06

What It Tests: Invalid credentials

Expected Result: 401, generic message, identical for wrong password and unknown email

Automated Test File: `server/tests/lab-03/auth.api.test.ts`

Final: Pass

Test ID: API-03 | Type: API

Requirement/AC: AC-06, BR-07

What It Tests: Inactive account, correct password

Expected Result: 403, deactivation message

Automated Test File: `server/tests/lab-03/auth.api.test.ts`

Final: Pass

Test ID: API-04 | Type: API

Requirement/AC: AC-07, BR-08

What It Tests: Logout

Expected Result: 204, cookie cleared, subsequent protected call returns 401; calling logout twice still 204

Automated Test File: `server/tests/lab-03/auth.api.test.ts`

Final: Pass

Test ID: API-05 | Type: API

Requirement/AC: FR-03

What It Tests: GET /api/auth/me

Expected Result: 200 with role and `mustChangePassword`; 401 unauthenticated

Automated Test File: `server/tests/lab-03/auth.api.test.ts`

Final: Pass

Test ID: API-06 | Type: API

Requirement/AC: AC-02, AC-14, BR-02, BR-10

What It Tests: Change password (forced)

Expected Result: 200, `mustChangePassword` cleared; rejects reusing initial password; rejects mismatch

Automated Test File: `server/tests/lab-03/auth.api.test.ts`

Final: Pass

Test ID: API-07 | Type: API

Requirement/AC: AC-02, FR-04

What It Tests: mustChangePassword logout

Expected Result: Any non-allowlisted route returns 403 while true

Automated Test File: `server/tests/lab-03/authorization.api.test.ts`

Final: Pass

Test ID: API-08 | Type: API

Requirement/AC: AC-04, BR-24

What It Tests: Requester requests Internal Notes

Expected Result: 403, empty body, no note content leaked

Automated Test File: `server/tests/lab-03/comments-notes.api.test.ts`

Final: Pass

Test ID: API-09 | Type: API

Requirement/AC: AC-03, BR-03

What It Tests: Client-supplied requesterId ignored

Expected Result: Authenticated identity determines ownership regardless of body/query override

Automated Test File: `server/tests/lab-02/create-ticket.api.test.ts` (API-03b)

Final: Pass

Test ID: API-10 | Type: API

Requirement/AC: AC-17, BR-32

What It Tests: Cross-requester ticket access

Expected Result: 404 (not 403), no existence confirmation

Automated Test File: `server/tests/lab-02/ticket-detail.api.test.ts` (API-10c)

Final: Pass

Test ID: API-10d | Type: API

Requirement/AC: FR-07

What It Tests: Unauthenticated access to every Requester route

Expected Result: 401 on GET/POST/PATCH tickets, GET/POST/DELETE attachments, the download route, categories, and systems — corrected in review of PR #65: the original claim listed categories/systems but not PATCH, attachments, download, or systems specifically, and no systems test file existed at all

Automated Test File: `server/tests/lab-01/{categories,systems}.test.ts`,
`server/tests/lab-02/{create-ticket,my-tickets,ticket-detail}.api.test.ts`

Final: Pass

Test ID: API-10e | Type: API

Requirement/AC: §5.1, §9

What It Tests: Attachment download endpoint (new in I-4 — did not exist in Lab 2)

Expected Result: Owner downloads 200; non-owner 404; soft-removed attachment 410

Automated Test File: `server/tests/lab-02/ticket-detail.api.test.ts` (API-12b, API-13)

Final: Pass

Test ID: API-10f | Type: Security

Requirement/AC: BR-32

What It Tests: POST/DELETE attachment ownership (added in review of PR #65 — the ownership fix itself had no non-owner test on these two routes, only GET/download)

Expected Result: Non-owner POST returns 404 and writes no file to disk; non-owner DELETE returns 404

Automated Test File: `server/tests/lab-02/ticket-detail.api.test.ts` (API-12c, API-13a)

Final: Pass

Test ID: API-11 | Type: API

Requirement/AC: FR-07

What It Tests: Unauthenticated access to any protected route

Expected Result: 401 across the route table

Automated Test File: `server/tests/lab-03/authorization.api.test.ts`

Final: Pass

Test ID: API-12 | Type: API

Requirement/AC: §6 matrix

What It Tests: Full role × endpoint authorization grid

Expected Result: Prints and asserts the matrix in `specification.md` §6 in one run

Automated Test File: `server/tests/lab-03/authorization.api.test.ts`

Final: Pass (now covers I-4/I-6/I-7 routes; still grows for I-8's admin routes)

Test ID: AUTHZ-01 | Type: API

Requirement/AC: §6 matrix

What It Tests: `requireRole` middleware — permitted/rejected role behavior

Expected Result: Permitted role passes through; other role 403 FORBIDDEN; no auth 401

Automated Test File: `server/tests/lab-03/authorization.api.test.ts`

Final: Pass

Test ID: AUTHZ-02 | Type: Security

Requirement/AC: BR-07, FR-07

What It Tests: Deactivation takes effect on next request, not at token expiry

Expected Result: A live session is rejected 403 the instant the account is deactivated

Automated Test File: `server/tests/lab-03/authorization.api.test.ts`

Final: Pass

Test ID: API-13 | Type: API

Requirement/AC: AC-18

What It Tests: Staff queue — search/filter/sort/pagination

Expected Result: Correct result sets per query; invalid param 400 naming the field

Automated Test File: `server/tests/lab-03/staff-queue.api.test.ts`

Final: Pass

Test ID: API-13n | Type: API

Requirement/AC: AC-18 (added in review of PR #67 — item 3: `page` had no upper bound, only `pageSize` did)

What It Tests: Staff queue — huge page number

Expected Result: An absurdly large `page` (e.g. `9999999999999999999`) returns 400 naming `page`, not an unhandled 500 from an oversized Prisma skip

Automated Test File: `server/tests/lab-03/staff-queue.api.test.ts` (API-13n)

Final: Pass

Test ID: API-14 | Type: API

Requirement/AC: FR-14

What It Tests: Staff queue — role restriction

Expected Result: Requester 403; IT Staff/Admin 200

Automated Test File: `server/tests/lab-03/staff-queue.api.test.ts`

Final: Pass

Test ID: API-28 | Type: API

Requirement/AC: AC-18 (added in review of PR #67 — item 2: no endpoint listed staff for the Owner filter picker)

What It Tests: `GET /api/staff/members` roster

Expected Result: Returns active IT_STAFF/ADMINISTRATOR users as `[{ id, name }]` ordered by name; Requester 403; unauthenticated 401

Automated Test File: `server/tests/lab-03/staff-queue.api.test.ts`

Final: Pass

Test ID: API-15 | Type: API

Requirement/AC: AC-08, BR-13, BR-14

What It Tests: Claim/reassign ownership

Expected Result: Owner set correctly; rejects an inactive or Requester-role ownerId

Automated Test File: `server/tests/lab-03/staff-ticket-detail.api.test.ts`

Final: Pass

Test ID: API-16 | Type: API

Requirement/AC: BR-16

What It Tests: Set IT Priority

Expected Result: Updates independently of Requested Priority; role-restricted

Automated Test File: `server/tests/lab-03/staff-ticket-detail.api.test.ts`

Final: Pass

Test ID: API-17 | Type: API

Requirement/AC: AC-09, BR-17, BR-19

What It Tests: Status transition enforcement

Expected Result: Legal transition succeeds; illegal 409 with permitted set; IN_PROGRESS blocked while unassigned

Automated Test File: `server/tests/lab-03/staff-ticket-detail.api.test.ts`

Final: Pass

Test ID: API-17b | Type: API

Requirement/AC: BR-17 (added in review of PR #68 — item 1: GET's permittedStatusTransitions did not apply the BR-17 filter that PATCH /status enforces, so an unassigned ticket's response could offer IN_PROGRESS as permitted even though applying it always 409'd)

What It Tests: GET /api/staff/tickets/:id — permittedStatusTransitions BR-17 filter

Expected Result: Excludes IN_PROGRESS for an unassigned ticket; includes it once the ticket has an owner

Automated Test File: `server/tests/lab-03/staff-ticket-detail.api.test.ts`

Final: Pass

Test ID: API-18 | Type: API

Requirement/AC: AC-10, BR-05

What It Tests: Requester resolution signal

Expected Result: Sets flag + auto-comment; status unchanged; Requester cannot set Resolved/Closed directly; blocked (409) once already terminal; 404 for non-owner

Automated Test File: `server/tests/lab-03/comments-notes.api.test.ts`

Final: Pass

Test ID: API-18f | Type: API

Requirement/AC: BR-05

What It Tests: Resolution-signal idempotency (added in review of PR #66 — no test called the route twice on the same still-open ticket)

Expected Result: A second call on the same open ticket returns 409, does not overwrite the timestamp, and does not create a duplicate comment

Automated Test File: `server/tests/lab-03/comments-notes.api.test.ts`

Final: Pass

Test ID: API-19 | Type: API

Requirement/AC: BR-04, BR-21, BR-22, BR-23, BR-32

What It Tests: Public Comments CRUD (create/list only)

Expected Result: Append-only (no PATCH/DELETE route); author/timestamp server-set; rejects blank/oversize content; 404 for non-owning Requester; 401 unauthenticated

Automated Test File: `server/tests/lab-03/comments-notes.api.test.ts`

Final: Pass

Test ID: API-20 | Type: API

Requirement/AC: BR-04, BR-21

What It Tests: Internal Notes CRUD (create/list only)

Expected Result: Staff/Admin only; append-only; same validation as comments

Automated Test File: `server/tests/lab-03/comments-notes.api.test.ts`

Final: Pass

Test ID: SEC-01 | Type: Security

Requirement/AC: (found capturing I-7's Part 7 curl evidence, not from a written requirement — every `include: { requester: true }` fetched the full `User` row, including `passwordHash`, into the ticket response; three Requester-facing routes since I-2, plus the new I-7 staff-detail route)

What It Tests: No ticket response ever includes `passwordHash`

Expected Result: `res.body.requester.passwordHash` is undefined and the raw JSON contains no `passwordHash` string, for both the Requester's own ticket detail and the staff detail route

Automated Test File: `server/tests/lab-02/ticket-detail.api.test.ts`,
`server/tests/lab-03/staff-ticket-detail.api.test.ts`

Final: Pass

Test ID: API-21 | Type: API

Requirement/AC: FR-20

What It Tests: Admin user list — search/role filter

Expected Result: Correct filtering; non-Admin 403

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-22 | Type: API

Requirement/AC: AC-11, BR-26

What It Tests: Create user — duplicate email

Expected Result: 409, case-insensitive match, no user created

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-23 | Type: API

Requirement/AC: FR-24

What It Tests: Create user — invalid role

Expected Result: 400

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-24 | Type: API

Requirement/AC: FR-22

What It Tests: Edit user — basic fields

Expected Result: Name/email/role/isActive update correctly

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-25 | Type: API

Requirement/AC: AC-14, FR-23

What It Tests: Set new initial password

Expected Result: `mustChangePassword` forced true; that user's next login requires change

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-26 | Type: API

Requirement/AC: AC-12, BR-27

What It Tests: Self-deactivation blocked

Expected Result: Admin cannot deactivate/demote own account

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-27 | Type: API

Requirement/AC: AC-13, BR-28

What It Tests: Last-Administrator protection

Expected Result: Deactivating/demoting the last active Admin rejected; a second active Admin may be deactivated

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-29 | Type: API

Requirement/AC: AC-13, BR-28 (added in review of PR #69 — item 1: TOCTOU race in the last-Administrator count-then-write)

What It Tests: Last-Administrator protection under real concurrency

Expected Result: Two concurrent PATCHes, each deactivating the other of exactly two active Administrators, via `Promise.all`: exactly one succeeds (200), the other is rejected (403 LAST_ADMINISTRATOR), and a fresh DB count immediately after confirms at least one active Administrator remains

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-30 | Type: API

Requirement/AC: AC-12, BR-27 vs BR-26 (added in review of PR #69 — item 4: ordering)

What It Tests: Self-modification check precedes duplicate-email check

Expected Result: A self-deactivation attempt whose body also collides on another user's email returns 403 SELF_MODIFICATION_BLOCKED, not 409 DUPLICATE_EMAIL

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: API-31 | Type: API

Requirement/AC: BR-26 (added in review of PR #69 — item 5: app-level email pre-check races the DB unique constraint)

What It Tests: Duplicate-email race on create

Expected Result: Two concurrent POST `/api/admin/users` with the same email via `Promise.all`: one succeeds (201), the other returns 409 DUPLICATE_EMAIL (not a 500), and only one row is created

Automated Test File: `server/tests/lab-03/users-admin.api.test.ts`

Final: Pass

Test ID: SEED-01 | Type: Manual code review

Requirement/AC: BR-02, BR-30

What It Tests: Existing-user seed upsert behavior (reviewed on PR #71)

Expected Result: The Requester `update: {}` branch preserves user edits on rerun; every `create` branch still sets the initial password and `mustChangePassword: true`

Automated Test File: `server/prisma/seed.ts`

Final: Reviewed in code; not an automated seed-rerun test

Test ID: REGR-01 | Type: Migration/Regression

Requirement/AC: BR-30, BR-31, AC-16

What It Tests: Baseline row floors and FK integrity after migration

Expected Result: Each evolved table has at least its pre-Lab-3 row count; no orphaned requesterId, original accounts retained, enum fields non-null, hashes non-plaintext. Exact before/after identity was checked manually during I-2

Automated Test File: `server/tests/lab-03/migration-regression.api.test.ts`

Final: Pass (five automated checks plus I-2 manual check)

Test ID: REGR-02 | Type: Migration/Regression

Requirement/AC: FR-10

What It Tests: Lab 1/2 endpoints still function under cookie auth

Expected Result: Rewritten Lab 2 API tests pass with session auth; Lab 1 categories/systems/health tests remain green

Automated Test File: `server/tests/lab-01/`, `server/tests/lab-02/`

Final: Pass

Client Tests — `client/tests/lab-03/`

Test ID: UI-01 | Type: UI Component

Requirement/AC: AC-01, AC-05

What It Tests: Login form

Expected Result: Valid submit calls API and redirects; invalid shows generic error; busy state disables button

Automated Test File: `client/tests/lab-03/Login.test.tsx`

Final: Pass

Test ID: UI-02 | Type: UI Component

Requirement/AC: AC-02, BR-09, BR-11

What It Tests: Change Password form

Expected Result: Validates policy and confirmation client-side; submits and redirects on success

Automated Test File: `client/tests/lab-03/ChangePassword.test.tsx`

Final: Pass

Test ID: UI-03 | Type: UI Component

Requirement/AC: FR-14

What It Tests: Staff Queue rendering

Expected Result: Renders rows with correct badges; empty and no-results states render correctly

Automated Test File: `client/tests/lab-03/StaffTicketQueue.test.tsx`

Final: Pass

Test ID: UI-04 | Type: UI Component

Requirement/AC: §1 (ui-spec)

What It Tests: Queue badges and Owner display

Expected Result: Status/priority badge markup and owner name vs. Unassigned label render; actual computed status/role colors are verified by VIS-01 in Chromium

Automated Test File: `client/tests/lab-03/StaffTicketQueue.test.tsx`

Final: Pass

Test ID: UI-05 | Type: Responsive

Requirement/AC: §9 (ui-spec)

What It Tests: Queue table card collapse

Expected Result: Card layout markup present alongside the desktop table (Bootstrap breakpoint classes; jsdom does not evaluate CSS media queries, so this asserts markup, not computed layout)

Automated Test File: `client/tests/lab-03/StaffTicketQueue.test.tsx`

Final: Pass

Test ID: UI-03e | Type: UI Component

Requirement/AC: FR-14 (added in review of PR #67 — item 1: "Open" navigated to a route `App.tsx` never defines, and no test caught it; superseded in I-7, which built that route; wording corrected in review of PR #68 — item 3: the I-6 modal was fully deleted, not preserved)

What It Tests: Queue "Open" action

Expected Result: Clicking a row's Open button navigates to the real `/staff/tickets/:id` Staff Ticket Detail screen (I-7). The I-6 read-only modal (`TicketDetailModal`) no longer exists at all; `onOpenTicket` is a bare optional callback that receives the clicked ticket id and renders nothing itself — a caller that passes it must build its own UI

Automated Test File: `client/tests/lab-03/StaffTicketQueue.test.tsx` (item-1)

Final: Pass

Test ID: UI-03f | Type: UI Component

Requirement/AC: AC-18 (added in review of PR #67 — item 2: Owner filter only offered All/Unassigned)

What It Tests: Queue Owner picker

Expected Result: Picker is populated from `GET /api/staff/members`; selecting a specific staff member sends the matching `ownerId` query param

Automated Test File: `client/tests/lab-03/StaffTicketQueue.test.tsx` (item-2)

Final: Pass

Test ID: UI-03g | Type: UI Component

Requirement/AC: FR-14 (added in review of PR #71 — old queue rows remained clickable while a new filtered request loaded or failed)

What It Tests: Staff Queue reload/error state

Expected Result: Previous rows and Open actions disappear during reload and after a failed fetch; skeleton then error message appear instead

Automated Test File: `client/tests/lab-03/StaffTicketQueue.test.tsx` (UI-03g)

Final: Pass

Test ID: UI-06 | Type: UI Component

Requirement/AC: FR-15, FR-16, FR-17

What It Tests: Staff Ticket Detail controls

Expected Result: Claim/reassign/IT Priority/status controls call the correct endpoints

Automated Test File: `client/tests/lab-03/StaffTicketDetail.test.tsx`

Final: Pass

Test ID: UI-07 | Type: UI Style

Requirement/AC: §7 (ui-spec)

What It Tests: Public Comment vs Internal Note panel styling

Expected Result: Distinct background/label rendered for each panel

Automated Test File: `client/tests/lab-03/StaffTicketDetail.test.tsx`

Final: Pass

Test ID: UI-08 | Type: UI Component

Requirement/AC: FR-20, FR-21, FR-22

What It Tests: User Management list/create/edit forms

Expected Result: Search/filter call correct query; create/edit submit correct payloads; inline validation renders

Automated Test File: `client/tests/lab-03/UserManagement.test.tsx`

Final: Pass

Test ID: UI-08i | Type: UI Regression

Requirement/AC: FR-21 (found during I-11 main-branch E2E run)

What It Tests: Create User while an older filtered-list request is still in flight

Expected Result: A post-write refresh aborts the older request; its stale response cannot overwrite the list containing the new account

Automated Test File: `client/tests/lab-03/usePaginatedFetch.test.tsx`; `e2e/lab-03/user-administration.spec.ts`

Final: Pass on I-11 branch; main recheck pending merge

Test ID: UI-09 | Type: UI Component

Requirement/AC: AC-12, AC-13

What It Tests: Admin safety rules surfaced in UI

Expected Result: Self-deactivation and last-Admin attempts show an inline blocking message

Automated Test File: `client/tests/lab-03/UserManagement.test.tsx`

Final: Pass

Test ID: UI-10 | Type: UI Component

Requirement/AC: FR-20 (added in review of PR #69 — item 9: no client test exercised RequireRole on a route this sensitive)

What It Tests: RequireRole guard on `/admin/users`

Expected Result: IT_STAFF and REQUESTER users are redirected away from `/admin/users` instead of it rendering; an ADMINISTRATOR user renders it normally

Automated Test File: `client/tests/lab-03/ProtectedRoute.test.tsx`

Final: Pass

Test ID: UI-11 | Type: UI Resilience

Requirement/AC: Defensive rendering for API status values

What It Tests: Shared status badge on staff and Requester screens

Expected Result: All eight current statuses and five Lab 2 spellings map to the correct palette and preserve `data-status`; unknown values (including prototype property names) use the neutral fallback

Automated Test File: `client/tests/lab-03/TicketStatusBadge.test.tsx`

Final: Pass

End-to-End Tests — e2e/lab-03/ (Playwright)

Test ID: E2E-01 | Type: E2E

Requirement/AC: AC-01, AC-07, AC-15

What It Tests: Login app logout blocked

Expected Result: Full session lifecycle; direct navigation to a protected route after logout redirects to `/login`

Automated Test File: `e2e/lab-03/authentication.spec.ts`

Final: Pass

Test ID: E2E-02 | Type: E2E

Requirement/AC: AC-02

What It Tests: Initial password login and change

Expected Result: Normal app opens only after a valid password change

Automated Test File: `e2e/lab-03/authentication.spec.ts`

Final: Pass

Test ID: E2E-03 | Type: E2E

Requirement/AC: FR-14–FR-19

What It Tests: Full staff workflow

Expected Result: Queue open Ticket claim (asserted visible and clicked unconditionally, then owner-select value confirmed to change — not merely that the Claim button disappeared; corrected in review of PR #70, item 2) set IT Priority change status post comment post note

Automated Test File: `e2e/lab-03/staff-ticket-flow.spec.ts`

Final: Pass

Test ID: E2E-04 | Type: E2E

Requirement/AC: FR-20–FR-23

What It Tests: Full admin workflow

Expected Result: Create user set initial password that user's forced change at next login

Automated Test File: `e2e/lab-03/user-administration.spec.ts`

Final: Pass

Test ID: VIS-01 | Type: UI Style

Requirement/AC: `ui-spec.md` §1, §10

What It Tests: Status and role badge palettes

Expected Result: All eight status colors and all three role badge backgrounds match their declared tokens

Automated Test File: `e2e/lab-03/visual-inspection.spec.ts` (palette and role-specific shell)

Final: Pass

Test ID: VIS-02 | Type: Responsive

Requirement/AC: `ui-spec.md §9–§10`

What It Tests: Responsive layout and clipping

Expected Result: Staff Queue fits its scroll region at 375/768/1024/1280px; Lab 3 screens have no page-level overflow at 375px; long status text fits its badge at 992px; mobile cards fit the viewport

Automated Test File: `e2e/lab-03/visual-inspection.spec.ts` (responsive/overflow/mobile cards/992px status)

Final: Pass

Test ID: VIS-03 | Type: Accessibility

Requirement/AC: `ui-spec.md §10`

What It Tests: Keyboard focus across roles and screen sizes

Expected Result: Every listed visible enabled Tab stop is reachable and has a visible focus indicator; attachment and administrator dialogs trap focus and support Escape/focus return

Automated Test File: `e2e/lab-03/visual-inspection.spec.ts` (focus sweeps and dialog tests)

Final: Pass

Test ID: VIS-04 | Type: UI Style

Requirement/AC: `ui-spec.md §10`

What It Tests: Form and information presentation

Expected Result: Queue Unassigned label vs detail Owner selector, public/internal panel backgrounds, read-only vs editable priority, and validation placement match the checklist

Automated Test File: `e2e/lab-03/visual-inspection.spec.ts` (owner/panels/priority/validation)

Final: Pass

Test ID: VIS-05 | Type: Security/UI

Requirement/AC: `ui-spec.md §10, §6 matrix`

What It Tests: Forbidden and not-found states

Expected Result: Staff cannot view admin route; unauthenticated direct navigation redirects to Login; missing ticket shows styled error

Automated Test File: `e2e/lab-03/visual-inspection.spec.ts` (forbidden/not-found)

Final: Pass

Test ID: VIS-06 | Type: Accessibility

Requirement/AC: `ui-spec.md §10`

What It Tests: Keyboard activation

Expected Result: Sortable queue headers and mobile ticket cards respond to keyboard activation

Automated Test File: `e2e/lab-03/visual-inspection.spec.ts` (keyboard sorting/mobile cards)

Final: Pass

The 23 tests in `e2e/lab-03/visual-inspection.spec.ts` are grouped under VIS-01–VIS-06 by the specific checklist property they verify. They support the visual inspection record as well as the four end-to-end workflows above.

Release-snapshot verification and I-11 correction

On 2026-10-05, the local checkout was detached at the exact `origin/main` merge commit `e48d2c8` before testing. `npm test` passed 251/251 server tests (16 files) and 69/69 client tests (11 files); the server and client production builds passed. The first `npx playwright test e2e/lab-03` run on that commit passed 29/30. E2E-04 failed after `POST /api/admin/users` returned 201: an older GET started while the POST was pending, returned a pre-create snapshot, and replaced the just-created account in the UI. The trace records the overlapping

requests; this was not reported as a pass.

I-11 adds a post-write list refresh and guards against results from aborted requests. The new UI-08i unit regression passes, as do the existing User Management tests and TypeScript check. Re-running the browser suite on the I-11 branch passed 30/30. A final browser run on `main` remains pending until the I-11 PR is reviewed and merged; the submitted PDF must state that result only after it is actually observed.

Part 7 Direct API Authorization Evidence

Cookie-jar `curl` transcripts (D-01: the session is an `httpOnly` cookie, so there is no bearer token to paste) captured 2026-09-17 against a running local server and the real dev database, per `sprint-plan.md` §6: `artifacts/lab-03/curl-transcripts-i7.txt`. Covers all six required scenarios (Requester internal notes 403 with no note content; Requester staff queue 403; Requester another Requester's ticket 404 masking per BR-32; IT Staff admin users; unauthenticated 401; `mustChangePassword` user 403), plus a bonus I-7 positive-path transcript (claim illegal transition 409 with permitted set).

The `IT-Staff--admin-users` scenario was originally captured as a `route-not-found` 404 (before I-8 existed), with a note deferring re-capture. I-8 (Administrator User Management) has since landed on this branch, and the transcript was re-captured against the real routes: it now shows the role-based 403 the scenario was always meant to demonstrate.

Capturing this transcript is also what surfaced SEC-01 above (the `passwordHash` leak) — the transcript file documents the finding, the fix, and a re-run of the same request confirming it.

Screenshot / Visual Evidence Traceability

Captured via `e2e/lab-03/capture.ts` (see `sprint-plan.md` §3). Folders exactly as required: `artifacts/lab-03/screenshots/{authentication,staff-queue,staff-ticket-detail,user-management}/`, no 5th folder. The latest full Lab 3 browser run passed 30/30 tests; the manifest below lists the checked-in evidence captures. User-management screenshots capture the responsive viewport rather than full-page content, so retained E2E fixture accounts do not make those images grow on each run:

Fixture-account dependency (review of PR #70, item 1): every spec in this directory authenticates as one of the `regression-suite-{requester,staff,admin}@toktick.internal` accounts. These are provisioned by `e2e/lab-03/global-setup.ts` (wired via `playwright.config.ts`'s `globalSetup`), which calls the same `ensureRegression*()` upserts `server/tests/helpers/testAuth.ts` defines, directly against Prisma, once before this whole suite runs. This is independent of the server's own vitest suite ever having run against the same database — a fresh clone that only migrates, seeds, and starts the dev servers now provisions these accounts itself before the first spec's `login()` call.

The `eight-status` palette test also requires at least one ticket in each `TicketStatus` state. `server/prisma/seed.ts` supplies that status distribution; the test fails if a filtered state has no badge, rather than silently skipping a missing status.

The `user-list` evidence capture applies the IT Staff role filter and searches for the seeded Carlos Mendez account. This keeps the screenshot representative of the real UI while avoiding accumulated throwaway accounts from test runs; the filters are cleared before the Create/Edit User workflow continues.

```
artifacts/lab-03/screenshots/authentication/Figure-after-logout@desktop.png
artifacts/lab-03/screenshots/authentication/Figure-change-password-success@desktop.png
artifacts/lab-03/screenshots/authentication/Figure-forced-change-password-
screen@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/authentication/Figure-login-form@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/authentication/Figure-login-success@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/staff-queue/Figure-queue-filtered-search@desktop.png
artifacts/lab-03/screenshots/staff-queue/Figure-queue-overview@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/staff-ticket-detail/Figure-ticket-detail-after-
actions@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/staff-ticket-detail/Figure-ticket-detail-
unclaimed@{desktop,tablet,mobile}.png
```

artifacts/lab-03/screenshots/user-management/Figure-create-user-modal@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/user-management/Figure-edit-user-modal@{desktop,tablet,mobile}.png
artifacts/lab-03/screenshots/user-management/Figure-user-list@{desktop,tablet,mobile}.png

Each figure referenced in the submitted PDF corresponds to a specific AC or FR from `specification.md`; the mapping is finalized in I-11 alongside the final `reviewer.md`.

Regression Baseline (recorded before any Lab 3 migration)

Correction (2026-09-16): the count below of Ticket 18 / Attachment 4, originally captured during Phase 0, was taken against the wrong database. This machine runs two independent PostgreSQL servers that both listen on port 5432 — a Docker container (`toktickit-db`, reachable only via `docker exec`) and a real Postgres 16 instance inside a WSL Ubuntu distro (reachable via `localhost:5432` from any host-side tool, including every `npx prisma` command, `npm run dev`, and this session's own Node scripts, because Windows routes `localhost` to the more specific `127.0.0.1`-bound listener). The Docker container turned out to be a stale, unused artifact from initial `docker-compose` setup (volume created 2026-08-12, ticket numbers randomly generated, never touched since); the WSL instance is the real one — its ticket numbers follow the sequential `TKT-2026-0001XX` scheme from the Lab 2 hardening fix, with timestamps through 2026-09-02 matching the actual session history. The Phase 0 backup and this baseline table have been redone against the WSL (real) database. `docker-compose.yml`'s `db` service now publishes port 5433 instead of 5432 to prevent this ambiguity recurring; its internal Docker-network traffic (`db:5432`, used by the `server` container) is unaffected either way.

Captured 2026-09-16 against the corrected pre-Lab-3 database, backed up to `artifacts/lab-03/db-backup-pre-lab3.sql`:

Table: Category | Row Count: 4

Table: RequesterUser | Row Count: 5

Table: RelatedSystem | Row Count: 7

Table: Ticket | Row Count: 15

Table: Attachment | Row Count: 5

Note (I-6, 2026-09-17): `staff-queue.api.test.ts` could not initially be run end-to-end because the Docker `db` container had drifted back onto host port 5432 (colliding with the real WSL-hosted Postgres, the same class of issue first diagnosed during I-2 — see the row counts above), which made the reachable `localhost:5432` connection land on an unrelated, unmigrated database. Recreating the container restored the correct 5433 mapping from `docker-compose.yml`, after which an orphaned, never-finished `_prisma_migrations` bookkeeping row (`20260812121902_init`, predating the current `0_init-4_add_comments_and_notes` sequence) was cleared with `npx prisma migrate resolve --rolled-back` — a bookkeeping-only fix, no schema or data change. All 99 server tests, including the 17 in `staff-queue.api.test.ts`, then passed.

REGR-01 automatically checks that current counts are at least these baseline counts, no `Ticket.requesterId` is orphaned, the original accounts remain, and no enum conversion introduced NULL values. It does not compare exact ticket IDs to a pre-migration snapshot. That stronger identity check was performed manually during I-2 (all 15 tickets and 5 attachments preserved).

Answer Part 4: AI Use with Reflection

The chronological AI-use log below highlights ten prompts for grading while preserving the full, append-as-work-happened record and the author's reflection.

AI-use source: [ai-use.md](#).

Rendered document: [docs/lab-03/ai-use.md](#)

Lab 3 — AI Use and Reflection

LLM/agent used: Claude (Opus 5 and Sonnet 5) via Claude Code CLI for the earlier sprint, including its built-in sub-agent tooling (used to run a 5-advisor "LLM Council" review of the sprint plan); Codex for the PR #71 release-review corrections and I-11 final verification/report work.

Entries are appended as prompts happen, not reconstructed at the end —

see docs/lab-03/sprint-plan.md §1 (Law 2).

1. Selected Key Prompts

Ten prompts highlighted for the submitted PDF: #1, #3, #6, #11, #16,

17, #20, #21, #22, and #24. The full chronological log remains below so

the selection does not erase the other decisions or corrections.

#: 1 | Exact Prompt Typed: `try to understand everything in the folder and create plan for lab3`

What I Did with the Result: Had the assistant read the full repo, the Lab 3 PDF handout, and prior session notes, then interview me (the "grilling" skill) on the 9 architectural decisions with the highest blast radius before any plan was written.

#: 2 | Exact Prompt Typed: `i would go with your plan but make sure it meet all criteria for the lab3(full score)`

What I Did with the Result: Directed the assistant to lock in its recommended answers and produce a full sprint plan (`docs/lab-03/sprint-plan.md v1`) traced against every rubric line.

#: 3 | Exact Prompt Typed: `spawn 5 more agents from this skill, your task is to talk to them and create plan that meet all criteria(full score), it should cover all correct workflow step.`

What I Did with the Result: Ran the plan through an adversarial 5-advisor council (Contrarian, First Principles, Expansionist, Outsider, Executor) plus 3 anonymized peer-review passes, then had the assistant synthesize the verdict itself (having read the repo, unlike the cold sub-agents) and rewrite the plan as v2.

#: 4 | Exact Prompt Typed: `tell me final plan now`

What I Did with the Result: Requested the finalized, human-readable version of the plan for direct execution.

#: 5 | Exact Prompt Typed: `no skip this part, i will have my other friend to do pull request too we have talked together already`

What I Did with the Result: Skipped the "confirm reviewer availability" step since it had already been agreed outside the tool; kept the rest of Phase 0 unchanged.

#: 6 | Exact Prompt Typed: `from now i want you to do everything and only ask for my approval when it do with github like issue and pull request`

What I Did with the Result: Narrowed the approval gate: local work (files, commands, migrations, Docker, tests) proceeds without asking; GitHub-visible actions (PRs, issues, remote branch deletions) still pause for explicit approval.

#: 7 | Exact Prompt Typed: `continue / go on / ok`

What I Did with the Result: Used to advance through Phase 0 execution steps (branch creation, dependency installs, Playwright setup, database backup, migration baseline) one confirmed step at a time.

#: 8 | Exact Prompt Typed: `you decide and do everything you only ask me when it deal with gh`

What I Did with the Result: Directed the assistant to execute I-2 (data model, migration, seed) end-to-end without per-step confirmation, reserving approval only for GitHub-visible actions. During execution the assistant discovered and independently resolved a real infrastructure bug: two Postgres servers both listening on port 5432 (a stale Docker container and the real WSL-hosted database), which had caused the Phase 0 backup and every `prisma migrate` bookkeeping call to silently target the wrong database.

#: 9 | Exact Prompt Typed: `continue`

What I Did with the Result: Used to move from I-2 into I-3 (authentication foundation): `login/logout/me/change-password` endpoints, the `requireAuth/requirePasswordChanged/requireRole` middleware, cookie-based sessions, and the corresponding test suites — again executed end-to-end under the GitHub-only approval gate.

#: 10 | Exact Prompt Typed: `continue`

What I Did with the Result: Used to move from I-3 into I-4 (auth UI, routing, Requester regression) — the sprint's largest issue. Wired `requireAuth/requirePasswordChanged` onto every existing Lab 2 route, removed the client-supplied `requesterId` contract, built the `Login/ChangePassword` screens and `react-router` route guards, deleted the Dev Requester selector, and rewrote all 6 existing server test files plus 5 client test files from `?requesterId=` to cookie-based auth. Also discovered and closed a real pre-existing security gap: the Lab 2 attachment "download" was a raw static-file link with no ownership or removal-state enforcement at all, despite the Lab 2 report describing 403/410 protection there — added a real checked download endpoint.

#: 11 | Exact Prompt Typed: `my friend did request change go fix it`

What I Did with the Result: Worked through all 9 findings from @projectnewy's Changes Requested review of PR #65 on the same branch (never opening a new PR, per the project's own workflow rules). Three were genuinely blocking: an unauthenticated static file mount left the exact ownership/removal gap the PR claimed to fix still open; the ownership check was duplicated across 3 routes instead of using the existing helper; and `multer` wrote attachment files to disk before the ownership check ran, so a rejected non-owner upload still left orphaned files. Consolidated all five ticket-scoped routes onto one `requireOwnedTicketParam` middleware, which incidentally fixed the disk-write-ordering bug as a side effect of fixing the duplication. Also added the missing non-owner and 401 test coverage the review flagged, replaced a shared-mutable-seeded-user test fixture that could race under parallel test execution with a second dedicated fixture, and corrected a `tests.md` claim that overstated existing coverage.

#: 12 | Exact Prompt Typed: `continue`

What I Did with the Result: After PR #65 merged, discovered mid-session that the local working directory had drifted onto a second git remote — the peer reviewer's own separate repository (`ninjo = @NinjoMUDA/Dechayut_3414Lab1`) — checked out on one of their branches, which meant the generated Prisma Client in `node_modules` had been built against their schema. This surfaced as ~40 TypeScript compile errors that looked alarming at a glance (wrong enum names, missing fields) but were entirely a stale-generated-artifact problem, not data loss: the assistant verified the actual git history, the live database schema, and row counts were all untouched before doing anything, then switched back to the correct branch and regenerated the Prisma Client. Built I-5 (Public Comments API/UI and the "Problem Appears Resolved" resolution signal) afterward.

#: 13 | Exact Prompt Typed: `continue`

What I Did with the Result: Worked through a second Changes Requested review, this time on PR #66 (Public Comments/resolution signal). Two findings were genuinely blocking: the resolution-signal route only checked terminal status, never whether it had already been signaled, so a retry silently overwrote the timestamp and duplicated the auto-comment on every call; and the new comments/resolution routes had reimplemented PR #65's just-consolidated 404-masking logic as a second, independent copy instead of extending it. Fixed the idempotency issue with a single conditional `updateMany` inside the transaction (atomic by construction — Postgres serializes concurrent updates to the same row) rather than a separate read-then-write check. Fixed the duplication by introducing one generic `fetchAuthorizedTicketOr404` core parameterized by an authorization predicate, with three thin call sites over it instead of three separate implementations. Also moved a client-side "which statuses block this button" list to the server as a single computed `canSignalResolution` field, eliminating an entire class of client/server drift the reviewer had flagged. Hit a real TypeScript quirk along the way — a `let` variable mutated inside an `async` transaction closure would not narrow past a null-check in the outer scope, resolving to `never` — and fixed it by having the transaction return its result into a fresh `const` instead of mutating a captured variable, which is also just better code.

#: 14 | Exact Prompt Typed: `continue`

What I Did with the Result: After PR #66 merged, moved to I-6 (IT Staff Ticket Queue): `GET /api/staff/tickets` (search/status/itPriority/categoryId/ownerId filters, sort+order, pagination, role-gated to IT Staff/Administrator) and the responsive Staff Queue screen. While verifying, hit a recurrence of the I-2 port-collision bug — the Docker `db` container had drifted back onto host port 5432, colliding with the real WSL-hosted Postgres — plus a separate, previously-undiscovered orphaned `_prisma_migrations` bookkeeping row from before the migrations were renamed to the current numbered scheme, which was blocking `prisma migrate status`. Diagnosed both from first principles (`netstat`, `docker ps`, direct `psql` against the WSL instance, `_prisma_migrations` table contents) before touching anything, confirmed the fix for each was

purely infrastructure/bookkeeping (recreating the container to pick up the corrected `docker-compose.yml` port mapping; `prisma migrate resolve --rolled-back` on the one orphaned row) with zero schema or data impact, then re-ran the full suite to confirm.

#: 15 | Exact Prompt Typed: `continue`

What I Did with the Result: Worked through the Changes Requested review of PR #67 (Staff Ticket Queue). Two findings were blocking: the "Open" action's default navigation target (`/staff/tickets/:id`) didn't exist anywhere in the router, so the queue's one specified action silently fell through to the Requester's own workspace on every click; and the Owner filter had no way to target a specific staff member, only "All"/"Unassigned", despite the API and UI spec both calling for a real picker. Fixed the first with a read-only detail modal built from data the queue already has, deliberately not pulling I-7's full staff detail screen (its own ownership panel, status transitions, internal notes, and not-yet-built `GET /api/staff/tickets/:id`) forward into this issue's scope — a real judgment call about issue boundaries, not just a smaller fix. Fixed the second by adding a minimal `GET /api/staff/members` roster endpoint, scoped no wider than the picker actually needs. Also addressed six non-blocking findings: extracted duplicated `search-debounce/categories-fetch/paginated-fetch` logic (previously copy-pasted from `MyTickets.tsx`, and already drifting) into a shared `usePaginatedFetch.ts` hook used by both screens; closed an unbounded-page path to Prisma; fixed a scenario where a stale out-of-range page rendered fully blank; added tablet-table sort headers to match desktop; trimmed an unused PII field from the response; and extracted a shared pagination/count core for the two ticket-listing routes, mirroring the `fetchAuthorizedTicketOr404` precedent from the PR #66 review.

#: 16 | Exact Prompt Typed: `continue`

What I Did with the Result: After PR #67 merged, built I-7 (IT Staff Ticket Detail — Part 7, the sprint's heaviest single rubric item): claim/reassign ownership, IT Priority, status-transition enforcement against the exact §6.5 matrix (`server/src/utils/statusTransitions.ts`, shared by the PATCH route, GET's new `permittedStatusTransitions` field, and unit tests), and Internal Notes. While personally capturing the Part 7 cookie-jar curl evidence the rubric requires (not delegated — this needed a live server and a real judgment call about which scenarios to run), discovered a genuine security bug myself: `GET /api/staff/tickets/:id`'s response included the requester's full User row, including `passwordHash`, because of an `include: { requester: true }` pattern repeated in five places (three pre-existing since I-2, one newly added). Fixed it immediately in the same branch with a `SAFE_REQUESTER_SELECT` projection and two regression tests, documented the finding and fix directly in the evidence transcript rather than silently correcting it, and honestly noted in both the transcript and `tests.md` that one required scenario (IT Staff admin users) can't be fully verified yet since `/api/admin/users` is I-8's still-unbuilt scope.

#: 17 | Exact Prompt Typed: `continue`

What I Did with the Result: Worked through the Changes Requested review of PR #68 (Staff Ticket Detail). Two findings were blocking: GET's `permittedStatusTransitions` didn't apply the same BR-17 unassigned-ticket filter that PATCH `/status` enforced, so the Status control could offer a choice guaranteed to 409 — fixed by extracting one shared `getPermittedTransitionsForTicket` helper used by both; and the evidence transcript from prompt 16 had committed a real bcrypt hash to git history even after the runtime leak was fixed. For the second one, rather than just adding a redacted version in a new commit (which would leave the real hash permanently visible in history), got explicit confirmation before amending the original commit with the value redacted and force-pushing — since the branch was solo and unmerged, this was low-risk, but I treated the amend/force-push combination as needing sign-off rather than doing it unilaterally, consistent with the standing rule that GitHub-visible/history-altering actions get a checkpoint. Also fixed eight non-blocking findings: corrected wording that inaccurately claimed a deleted I-6 modal "remains available"; removed a redundant re-fetch-after-write in three PATCH handlers; extracted a shared `PublicCommentsPanel` (fixing an already-drifted role-badge-suppression behavior); switched to a shared `formatDate`; extracted a shared staff-roster fetch hook; corrected a CSS variable to match the spec's documented value; extracted shared `save/error/success` boilerplate; and named a previously ad hoc Prisma projection constant.

#: 18 | Exact Prompt Typed: `continue`

What I Did with the Result: The reviewer followed up (not blocking, but correcting the record) that my claim about the force-push having removed the leaked hash "from history" overstated what actually happened: force-push only moves the branch ref, it doesn't garbage-collect the orphaned commit, and the old commit was still fetchable by exact SHA directly from GitHub — which the reviewer verified concretely (`git fetch` by SHA, the GitHub API, and `git show <sha>:<path>` all still returned the real hash). This was a good catch of me overclaiming a fix's completeness rather than its actual scope. Corrected `reviewer.md` and `ai-use.md` to state the accurate result — the hash is off the branch's reachable history (what a diff or a clone of the branch tip will show) but not purged from GitHub's underlying object storage (which would require GitHub Support) — instead of the earlier overstated "gone from history." Left the practical risk assessment as-is (low, since it's a fixture account whose plaintext password is already committed in source), but the lesson is to describe what a git operation actually does, not what it colloquially sounds like it does.

#: 19 | Exact Prompt Typed: `continue`

What I Did with the Result: After PR #68 merged, built I-8 (Administrator User Management): user list with search/role filter, create/edit forms, set-new-initial-password, and the three safety rules (no duplicate email, no self-deactivation, no

removing the last active Administrator) — all Administrator-only, unlike the staff routes which also allow IT_STAFF. Every response uses a `select-only` projection (`SAFE_ADMIN_USER_SELECT`), directly following the `SAFE_REQUESTER_SELECT` precedent from I-7's passwordHash-leak fix, so that class of bug didn't recur here.

#: 20 | Exact Prompt Typed: `continue`

What I Did with the Result: Worked through the Changes Requested review of PR #69 (Admin User Management). One finding was blocking and genuinely serious: the last-active-Administrator safety check had a real TOCTOU race — a plain count-then-write with no lock meant two concurrent requests deactivating each other of exactly two remaining Administrators could both pass and leave zero, exactly the outcome the rule exists to prevent. Fixed it properly rather than superficially: wrapped the check and the write in one transaction and took an explicit `SELECT ... FOR UPDATE` row lock on the active-Administrator set before counting, which is what actually closes the race (a bare transaction at Postgres's default isolation level does not). Explicitly considered and rejected two alternatives — Serializable isolation (would force a retry loop onto every caller for a guarantee the lock gives more cheaply) and the resolution-signal route's atomic-conditional-UPDATE pattern from an earlier review (doesn't fit here because that pattern's condition lives on the row being updated itself, while this rule's condition depends on the state of other rows) — and wrote a real concurrency test firing two simultaneous requests to prove the fix, rather than just asserting the sequential cases already covered. Also fixed eight non-blocking findings, including re-capturing a piece of Part 7's evidence transcript that had been left as a stale "will re-capture once I-8 lands" placeholder, now that I-8's routes actually exist.

#: 21 | Exact Prompt Typed: `continue`

What I Did with the Result: After PR #69 merged, built I-9 (three Playwright E2E specs, a full re-run of the screenshot capture harness across all four required folders, and the `ui-spec.md` visual inspection checklist). Doing this surfaced a real process gap worth recording honestly rather than glossing over: `sprint-plan.md` §3 states the capture harness would be "extended by each feature issue" with "no feature PR merges until its own screenshots and its own Playwright spec are in the branch" — but checking the actual repository state at the start of I-9, every screenshot folder was still empty and no `.spec.ts` files existed anywhere in `e2e/1ab-03/` beyond the Phase-0 harness stub. None of I-4 through I-8 actually did this incrementally, despite the plan calling for it explicitly as a "law." I-9 ended up doing the full capture in one consolidated pass instead of the intended per-issue drip, which is what the issue's own body ("full re-run of the capture harness ... and the complete screenshot manifest re-run") already anticipated as a fallback, so the deliverable itself isn't short — but the process deviated from the plan as written, and I'm recording that plainly rather than letting `reviewer.md/tests.md` imply a discipline that wasn't actually followed. While building it, also found and fixed a real bug in the shared `login()` helper other specs would have inherited silently (a label-matching collision with the "Show password" button, plus an unawaited redirect that could race a spec's next navigation), and worked through the visual checklist by writing actual Playwright assertions rather than eyeballing screenshots — three items came back honestly unverifiable or false-as-currently-built (the Navbar's role badge isn't rendered at all on the Staff/Admin screens, only the Requester's) rather than being checked off to look complete.

#: 22 | Exact Prompt Typed: `continue`

What I Did with the Result: Worked through the Changes Requested review of PR #70 (E2E and visual inspection). The reviewer opened by confirming the prior round's honesty (the unchecked checklist items and the process-deviation admission) held up against the actual code — a useful signal that recording gaps plainly, rather than minimizing them, doesn't cost credibility with a real reviewer. One finding was genuinely blocking: every E2E spec's fixture accounts were only ever created as a side effect of the server's own vitest suite happening to run first against the same database, so the "13/13 passing" claim wasn't actually reproducible from a fresh clone as documented — a real gap in exactly the kind of claim this rubric cares about. Fixed it with a proper Playwright `globalSetup` that provisions the fixtures directly, and — notably — verified the fix by deliberately corrupting the fixture rows and re-running the suite to confirm they were actually repaired, rather than trusting the code looked right. Also fixed a test that could pass for the wrong reason (a Claim-button check silently skippable if the button stopped rendering) and two checklist items that claimed more than their backing tests verified, correcting the claims to match reality rather than either fixing unrelated code to match an aspirational claim or leaving the claim inflated.

#: 23 | Exact Prompt Typed: `check`

What I Did with the Result: Checked the open release PR #71 and found @projectnewy's Changes Requested review. The review exposed a process error: quality/ally commit `047b5bf` was pushed directly to `1ab3-staging` without a feature PR. That commit is being reviewed for the first time in PR #71; logging it now cannot undo the deviation. It also exposed a real Staff Queue bug (old rows stayed clickable after a failed filtered fetch) and two visual-checklist claims stronger than their tests. Began corrections on a separate local feature branch, added a regression test for the stale rows, and aligned the checklist with actual assertions. The Administrator authorization wording was clarified to match the existing matrix, API spec, and server guards: this project explicitly grants the listed staff ticket operations to Administrators. The review and decision are recorded in `reviewer.md`; they were not reviewed before the direct staging push.

#: 24 | Exact Prompt Typed: `continue`

What I Did with the Result: On the final-report issue, checked the merged release and actual Kanban state, finished the missing `1ab3-release` tag and #59 Done card with explicit approval, then ran the complete test suites on the exact `main` merge commit. Server 251/251 and client 69/69 passed, but browser E2E initially passed only 29/30: the User Management

screen let an older list fetch overwrite the result of a successful Create User request. Used the recorded network trace (POST 201 overlapping GET 200) to identify the race, added an aborted-request guard and post-write refresh, wrote a regression test, and re-ran the branch browser suite to 30/30. The initial failure remains in `tests.md`; the final `main` recheck is pending the I-11 review/merge.

(A GitHub personal access token was pasted into chat during this sprint. It was not used for any operation — entering API keys/tokens is a hard rule the assistant does not cross regardless of instruction — and the user was told to revoke it immediately.)

2. My Reflection

On the specification agent: Asking the assistant to read the actual repo before writing anything mattered more than expected. The first pass (before grilling) would have guessed at things like the auth mechanism and the migration story; instead it surfaced concrete, verifiable facts — an uncommitted working tree on `main`, no Prisma migrations folder, a "Playwright 34/34" claim in Lab 2 docs for a suite that doesn't exist in the repo — that directly shaped decisions later. The grilling format (numbered questions with a recommended default, one round at a time) kept me making the actual decisions rather than the assistant assuming them.

On the coding/review agent: The council step caught a real bug I would not have caught myself: I had approved a plan that adopted Prisma native enums for Role/Status/Priority without noticing that Prisma's generated SQL for a `String` → `enum` conversion is destructive (`DROP COLUMN`), which would have silently deleted the existing Lab 2 ticket data on the very first migration. Two independent advisors flagged it, a third reviewer verified the specific mechanism, and the plan was rewritten to require hand-edited `USING` casts rehearsed against a backup before touching the working database — which I then executed personally as one of the very first Phase 0 steps, in that order. The council also caught that "rendered" in the rubric was doing 35 points of work I had glossed over, and that `reviewer.md/tests.md` couldn't be written only at the end without contradicting the anti-backfilling rule they document.

Where I stayed the human decision-maker: whether to keep or drop the Lab 2 hygiene branch (I dropped it — a judgment call about scope, not something the assistant should decide), and the choice to narrow the approval gate to GitHub-only actions once I trusted the plan enough not to need a checkpoint on every local command.

On I-2 specifically: loosening the approval gate had an immediate payoff — the assistant caught something a step-by-step confirmation flow likely wouldn't have surfaced as clearly: a `db pull` and a `docker exec` query disagreeing about the same "toktickit" database's data. Rather than proceeding on the assumption that whichever database it had already backed up was correct, it treated the discrepancy as a stop condition, gathered evidence (process ownership of the port, ticket-numbering patterns, timestamps) to determine which database was real, then redid the Phase 0 backup and the already-applied migration bookkeeping against the correct one before continuing. That is exactly the kind of infrastructure assumption I would want checked rather than silently trusted.

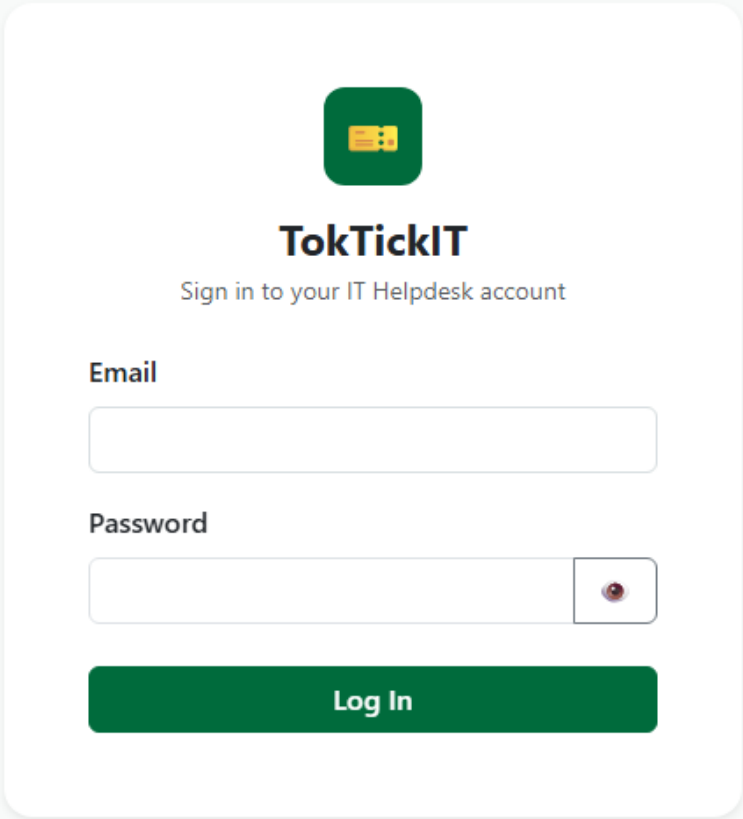
On I-4 specifically: the assistant made a real mistake mid-issue — it created `client/src/api.ts` for a new fetch helper without first checking whether that path already existed, silently overwriting a genuine Lab 1 file (`checkSystem()`) that a passing test still depended on. It was caught immediately because `tsc` and the test suite both failed loudly, and the fix was to merge the new helper into the original file rather than re-deleting history. The lesson I'd draw: an agent creating a "new" file should still check for a collision first, the same discipline it already applies to editing an existing one. Separately, building the ownership rewiring surfaced a real, pre-existing gap worth flagging on its own — the Lab 2 attachment "download" link was never actually access-controlled, just a raw static file path, contradicting what the Lab 2 report claims about 403/410 protection. That's now fixed with a real endpoint, but it's a good example of documentation asserting a security property that the code never actually enforced.

On I-9 specifically: `sprint-plan.md` §3 called the evidence harness "built once, used by every issue" with an explicit rule that no feature PR merges without its own screenshots and its own Playwright spec already in the branch. That rule was never actually followed from I-4 through I-8 — every screenshot folder was still empty at the start of I-9, and no spec files existed beyond the Phase-0 stub. I noticed this only because I-9's own scope

forced a direct check of the repository state rather than trusting the plan's description of how things had gone. Rather than have I-9's own docs imply the harness had been used incrementally all along, I recorded the gap plainly in prompt 21 above: the deliverable (full E2E coverage and a complete screenshot manifest) landed, but the process was a single consolidated catch-up, not the disciplined per-issue drip the plan described. I'd rather a reviewer or grader read an accurate account of a process that slipped than a tidy one that didn't happen. The technical work itself was solid — writing real Playwright assertions for the visual checklist (rather than eyeballing screenshots) directly surfaced that the Navbar's role badge doesn't render at all on the Staff/Admin screens, a genuine gap the checklist would have silently passed if I'd just looked at a screenshot and decided it looked fine.

Answer Part 5: Working Login and Password Change UI

The image series shows the login form, forced first-password change, successful continuation and logout at desktop, tablet, and mobile where available. Invalid credentials, inactive accounts and safe errors are covered by the auth API/component tests; these conditions are not falsely claimed as separate screenshots.



The image shows a login form for TokTickIT. At the top is a green square icon with a yellow ticket. Below it is the text "TokTickIT" in bold, followed by "Sign in to your IT Helpdesk account". There are two input fields: "Email" and "Password". The "Password" field has a toggle icon on the right. Below the fields is a green "Log In" button.



TokTickIT

Sign in to your IT Helpdesk account

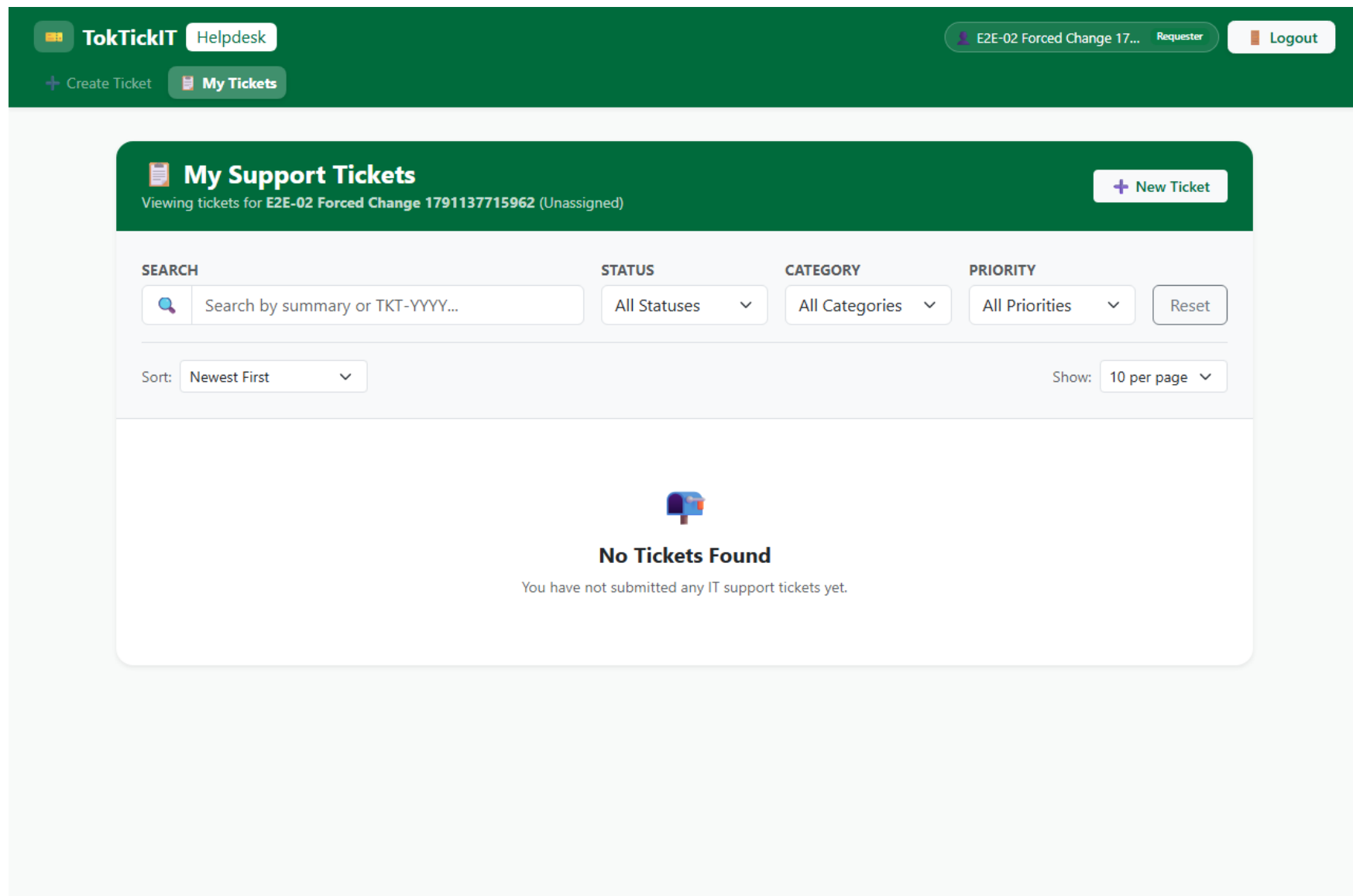
Email

Password



Log In

Figure 5.1: After logout desktop.



TokTickIT IT Helpdesk MVP — CPE 334 Software Engineering

Figure 5.2: Change password success desktop.

Change Your Password

For security, you must set a new password before continuing.

Current Password

New Password

Confirm New Password

- ☐ At least 8 characters
- ☐ Contains a letter
- ☐ Contains a digit
- ☐ Matches confirmation

Save New Password

Figure 5.3: Forced change password screen desktop.

Change Your Password

For security, you must set a new password before continuing.

Current Password

New Password

Confirm New Password

- ☐ At least 8 characters
- ☐ Contains a letter
- ☐ Contains a digit
- ☐ Matches confirmation

Save New Password

Figure 5.4: Forced change password screen mobile.

Change Your Password

For security, you must set a new password before continuing.

Current Password

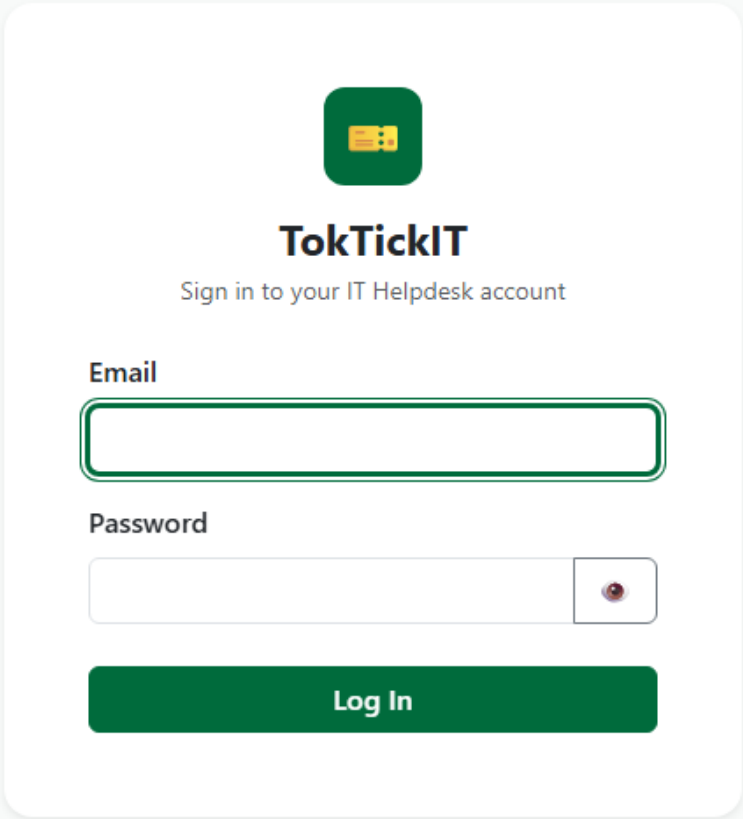
New Password

Confirm New Password

- ☐ At least 8 characters
- ☐ Contains a letter
- ☐ Contains a digit
- ☐ Matches confirmation

Save New Password

Figure 5.5: Forced change password screen tablet.



The image shows a desktop login form for TokTickIT. At the top is a green square icon with a yellow ticket. Below it is the text "TokTickIT" and "Sign in to your IT Helpdesk account". There are two input fields: "Email" and "Password". The "Email" field is a simple text box. The "Password" field is a text box with a toggle icon on the right. Below the fields is a green "Log In" button.



TokTickIT

Sign in to your IT Helpdesk account

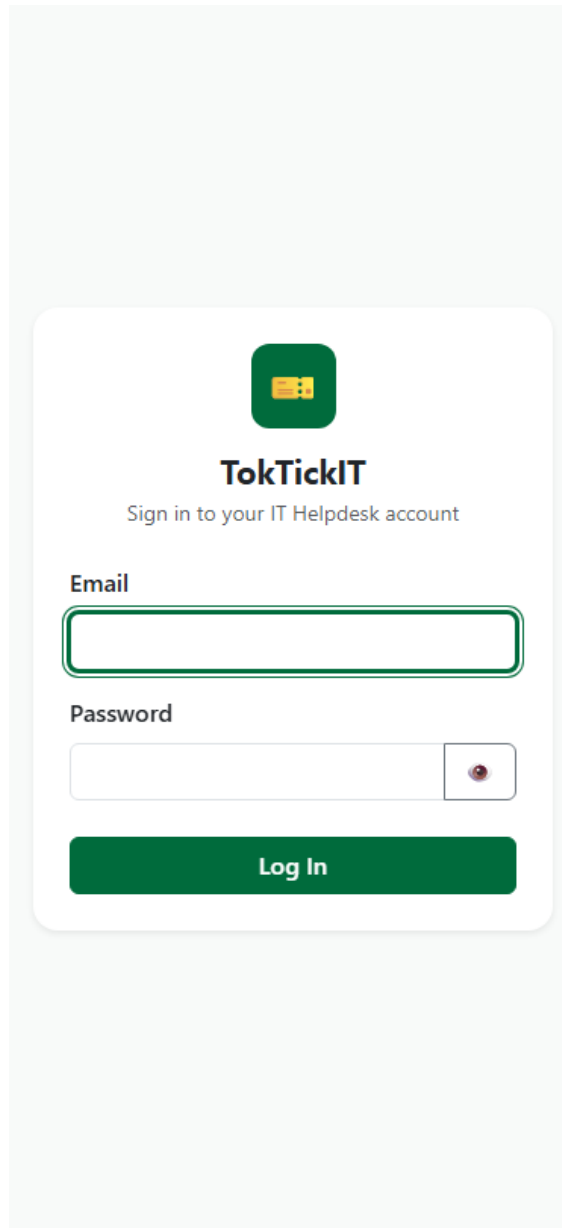
Email

Password



Log In

Figure 5.6: Login form desktop.



The image shows a mobile login form for TokTickIT. At the top is a green square icon with a yellow ticket. Below it is the text 'TokTickIT' and 'Sign in to your IT Helpdesk account'. There are two input fields: 'Email' and 'Password'. The 'Email' field is a simple white box with a green border. The 'Password' field is a white box with a green border and a small eye icon to its right. Below the password field is a green 'Log In' button.



TokTickIT

Sign in to your IT Helpdesk account

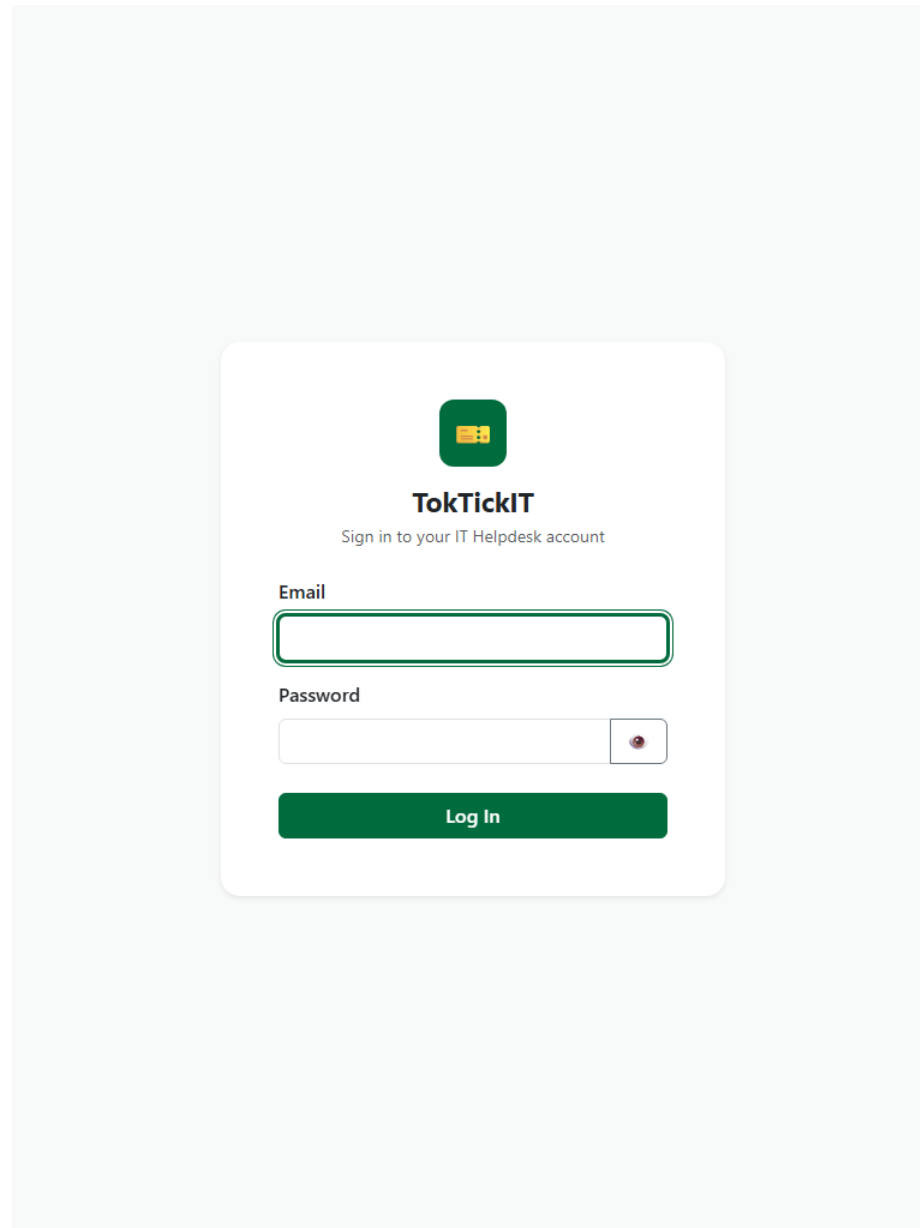
Email

Password



Log In

Figure 5.7: Login form mobile.



The image shows a login form for TokTickIT on a tablet screen. The form is centered on a light gray background. At the top is a green square icon with a yellow ticket and a person. Below the icon is the text "TokTickIT" in bold, followed by "Sign in to your IT Helpdesk account" in a smaller font. There are two input fields: "Email" and "Password". The "Email" field is a simple white box with a green border. The "Password" field is a white box with a green border and a small eye icon to its right. Below the password field is a green "Log In" button.



TokTickIT

Sign in to your IT Helpdesk account

Email

Password



Log In

Figure 5.8: Login form tablet.

[Helpdesk](#)

[Regression Suite Requester](#)
[Requester](#)
[Logout](#)

[+ Create Ticket](#)
[My Tickets](#)

My Support Tickets

Viewing tickets for Regression Suite Requester (QA)

+ New Ticket

SEARCH

STATUS

All Statuses

CATEGORY

All Categories

PRIORITY

All Priorities

Reset

Sort: Newest First

Show: 10 per page

TICKET #	SUMMARY	CATEGORY	SYSTEM	PRIORITY	STATUS	CREATED	ACTION
TKT-2026-406615	E2E fixture ticket 1791137435654	Account and Access	—	Medium	New	Oct 5, 2026	View Detail →
TKT-2026-289879	E2E fixture ticket 1791137432165	Account and Access	—	Medium	New	Oct 5, 2026	View Detail →
TKT-2026-343665	E2E fixture ticket 1791137406784	Account and Access	—	Medium	In Progress	Oct 5, 2026	View Detail →
TKT-2026-CLS381048	Already closed fixture	Account and Access	—	Low	Closed	Oct 5, 2026	View Detail →
TKT-2026-IDP380995	Idempotency fixture	Account and Access	—	Low	New	Oct 5, 2026	View Detail →
TKT-2026-STF380890	Status-field-spoof fixture	Account and Access	—	Low	New	Oct 5, 2026	View Detail →
TKT-2026-TEST380667	Updated Summary for In-Place Edit Test	Account and Access	—	Urgent	New	Oct 5, 2026	View Detail →
TKT-2026-CMT380629	Comments/resolution-signal fixture tic...	Account and Access	—	Medium	New	Oct 5, 2026	View Detail →
TKT-2026-987325	Ownership Override Attempt	Account and Access	—	Medium	New	Oct 5, 2026	View Detail →
TKT-2026-803449	Automated Test Ticket Submission 1 attachment	Account and Access	—	High	New	Oct 5, 2026	View Detail →

Showing page 1 of 29 (287 total tickets)

<

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

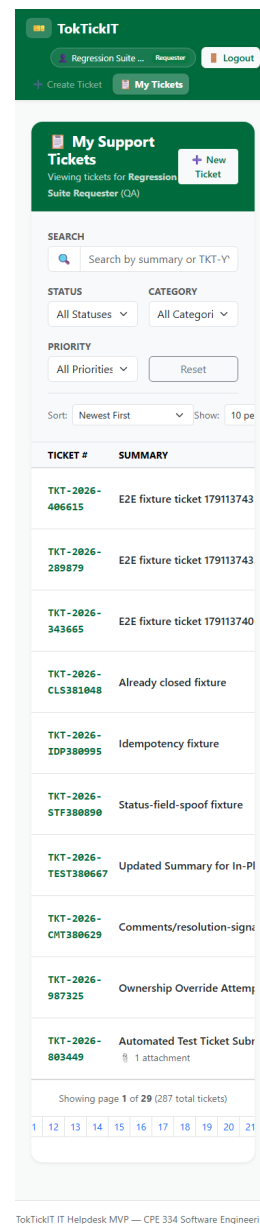
29

Next >

Prev

TokTickIT IT Helpdesk MVP — CPE 334 Software Engineering

Figure 5.9: Login success desktop.



TokTickIT IT Helpdesk MVP — CPE 334 Software Engineering

Figure 5.10: Login success mobile.

TokTickIT

Helpdesk

Regression Suite Requester

Requester

Logout

Create Ticket

My Tickets

My Support Tickets

Viewing tickets for Regression Suite Requester (JA)

New Ticket

SEARCH

STATUS

CATEGORY

PRIORITY

Reset

Search by summary or TK

All St

All Ca

All Pri

Sort: Newest First

Show: 10 per page

TICKET #	SUMMARY	CATEGORY	SYSTEM	PF
TKT-2026-406615	E2E fixture ticket 1791137435654	Account and Access	—	
TKT-2026-289879	E2E fixture ticket 1791137432165	Account and Access	—	
TKT-2026-343665	E2E fixture ticket 1791137406784	Account and Access	—	
TKT-2026-CLS381048	Already closed fixture	Account and Access	—	
TKT-2026-IDP380995	Idempotency fixture	Account and Access	—	
TKT-2026-STF380890	Status-field-spoof fixture	Account and Access	—	
TKT-2026-TEST380667	Updated Summary for In-Place Edit Test	Account and Access	—	
TKT-2026-CMT380629	Comments/resolution-signal fixture tic...	Account and Access	—	
TKT-2026-987325	Ownership Override Attempt	Account and Access	—	
TKT-2026-803449	Automated Test Ticket Submission 1 attachment	Account and Access	—	

Showing page 1 of 29 (287 total tickets)

<

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

Prev

TokTickIT IT Helpdesk MVP — CPE 334 Software Engineering

Figure 5.11: Login success tablet.

Answer Part 6: Working IT Staff Ticket Queue UI

The queue evidence shows real seeded tickets, ownership and priority/status badges, search/filter results, and three responsive layouts. Queue API tests cover sorting, pagination, invalid queries and role restrictions; browser tests cover navigation, no-results and visual behavior.

Helpdesk

Regression Suite Staff
IT Staff
Logout

Ticket Queue

IT Staff Ticket Queue

SEARCH

TKT-2026-310282

STATUS

All

IT PRIORITY

All

CATEGORY

All

OWNER

All

Ticket Number	Created Date	Summary	Category	Requested Priority	IT Priority	Status	Owner	Last Updated	Action
TKT-2026-310282	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-406615	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-289879	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-343665	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	HIGH	IN PROGRESS	Regression S...	Oct 5, 2026	Open
TKT-2026-STD38196...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38195...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38193...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	CANCELLED	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38186...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	IN PROGRESS	Regression S...	Oct 5, 2026	Open
TKT-2026-AUZ38187...	Oct 5, 2026	Authorization grid fixtu...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38185...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open

Page 1 of 91 (906 total)

« Prev
Next »

Figure 6.1: Queue filtered search desktop.

Helpdesk

Regression Suite Staff
IT Staff
Logout

Ticket Queue

IT Staff Ticket Queue

SEARCH

Search ticket #, summary, description, requester...

STATUS

All

IT PRIORITY

All

CATEGORY

All

OWNER

All

Ticket Number	Created Date	Summary	Category	Requested Priority	IT Priority	Status	Owner	Last Updated	Action
TKT-2026-310282	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-406615	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-289879	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-343665	Oct 5, 2026	E2E fixture ticket 17911...	Account a...	MEDIUM	HIGH	IN PROGRESS	Regression S...	Oct 5, 2026	Open
TKT-2026-STD38196...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38195...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38193...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	CANCELLED	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38186...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	IN PROGRESS	Regression S...	Oct 5, 2026	Open
TKT-2026-AUZ38187...	Oct 5, 2026	Authorization grid fixtu...	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open
TKT-2026-STD38185...	Oct 5, 2026	Staff ticket detail fixture	Account a...	MEDIUM	MEDIUM	NEW	Unassigned	Oct 5, 2026	Open

Page 1 of 91 (906 total)

« Prev
Next »

Figure 6.2: Queue overview desktop.

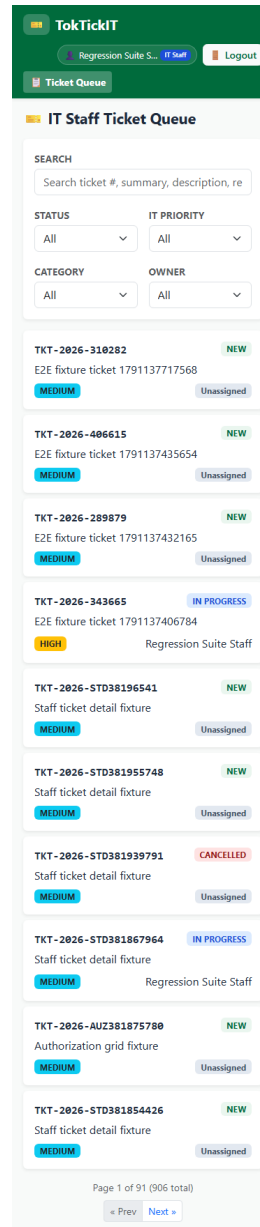


Figure 6.3: Queue overview mobile.

[Helpdesk](#)

Regression Suite Staff
IT Staff
Logout

Ticket Queue

IT Staff Ticket Queue

SEARCH

STATUS
All

IT PRIORITY
All

CATEGORY
All

OWNER
All

Ticket Number	Summary	Status	IT Priority	Owner	Act
TKT-2026-310282	E2E fixture ticket 17911...	NEW	MEDIUM	Unassigned	
TKT-2026-406615	E2E fixture ticket 17911...	NEW	MEDIUM	Unassigned	
TKT-2026-289879	E2E fixture ticket 17911...	NEW	MEDIUM	Unassigned	
TKT-2026-343665	E2E fixture ticket 17911...	IN PROGRESS	HIGH	Regression Suite Staff	
TKT-2026-STD38196541	Staff ticket detail fixture	NEW	MEDIUM	Unassigned	
TKT-2026-STD381955748	Staff ticket detail fixture	NEW	MEDIUM	Unassigned	
TKT-2026-STD381939791	Staff ticket detail fixture	CANCELLED	MEDIUM	Unassigned	
TKT-2026-STD381867964	Staff ticket detail fixture	IN PROGRESS	MEDIUM	Regression Suite Staff	
TKT-2026-AUZ381875780	Authorization grid fixture	NEW	MEDIUM	Unassigned	
TKT-2026-STD381854426	Staff ticket detail fixture	NEW	MEDIUM	Unassigned	

Page 1 of 91 (906 total)

« Prev
Next »

Figure 6.4: Queue overview tablet.

Answer Part 7: Working IT Staff Ticket Detail UI

The detail screens show unclaimed and post-action states across viewports. Ownership, IT Priority, permitted status changes, Public Comments, Internal Notes, attachments and Requester resolution signaling are covered by linked API/UI/E2E tests.

Helpdesk

Regression Suite Staff IT Se

← Back to Queue

TKT-2026-310282

IN PROGRESS

MEDIUM

Created Oct 5, 2026 • Last updated Oct 5, 2026

REQUESTER

Regression Suite Requester

QA

regression-suite-requester@toktick.internal

CATEGORY

Account and Access

RELATED SYSTEM

None / General IT

E2E fixture ticket 1791137717568

DESCRIPTION

Created by e2e/lab-03/staff-ticket-flow.spec.ts (I-9) for an isolated staff workflow run.

 Ownership & Priority

Figure 7.1: Ticket detail after actions desktop (detail segment 1/3).

Ownership & Priority

Owner updated.

Owner

Regression Suite Staff



Requested Priority (read-only)

MEDIUM

IT Priority

HIGH



Save IT Priority

IT Priority updated.

Status

Status updated.

Change status to

Select a status...



Apply

Attachments (0)

No active attachments on this ticket.

Public Comments

Figure 7.2: Ticket detail after actions desktop (detail segment 2/3).

NO ACTIVE ASSIGNMENTS ON THIS TICKET

Public Comments

Regression Suite Staff **IT Staff**

Oct 5, 2026, 01:15 AM

E2E staff comment 1791137719676

Add a comment

Share an update visible to the Requester...

Post Comment

Internal Notes **Internal — not visible to Requester**

Regression Suite Staff

Oct 5, 2026

E2E staff internal note 1791137719738

Add an internal note

Not visible to the Requester...

Post Internal Note

Figure 7.3: Ticket detail after actions desktop (detail segment 3/3).

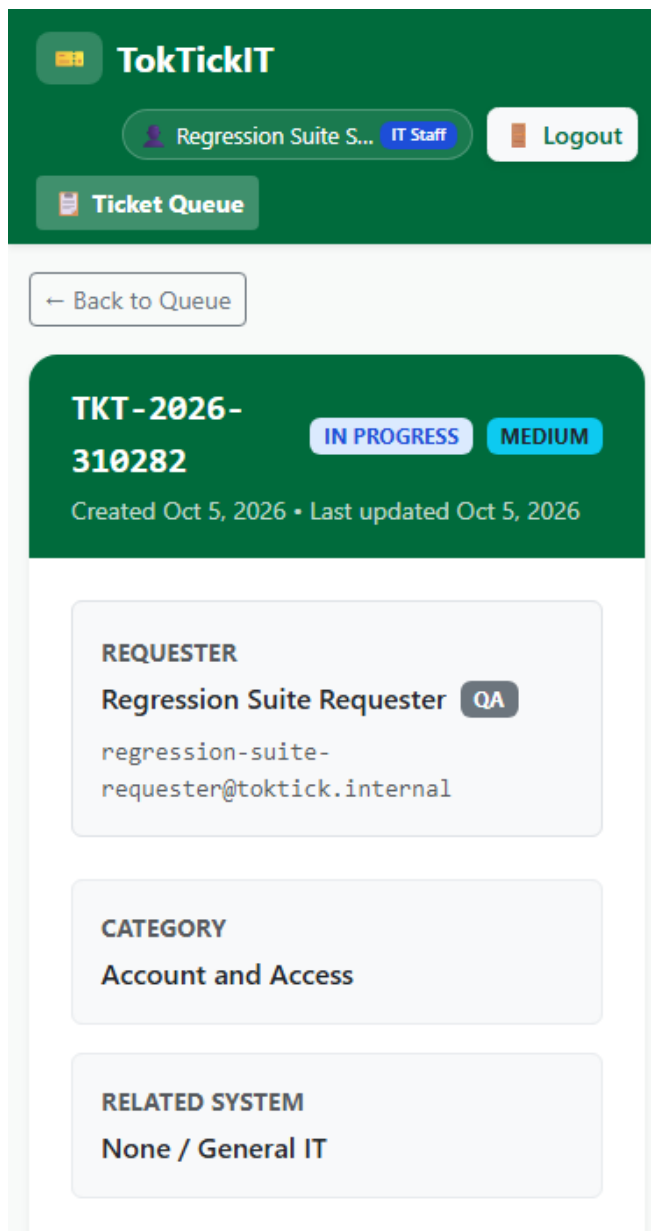


Figure 7.4: Ticket detail after actions mobile (detail segment 1/4).

None / General IT

E2E fixture ticket
1791137717568

DESCRIPTION

Created by e2e/lab-03/staff-ticket-flow.spec.ts (1-9) for an isolated staff workflow run.

 **Ownership & Priority**

Owner updated.

Owner

Regression Suite Staff

Requested Priority (read-only)

MEDIUM

IT Priority

HIGH

Save IT Priority

Figure 7.5: Ticket detail after actions mobile (detail segment 2/4).

Save IT Priority

IT Priority updated.

Status

Status updated.

Change status to

Select a status...

▼

Apply

Attachments (0)

No active attachments on this ticket.

Public Comments

Regression Suite Staff

IT Staff

Oct 5, 2026, 01:15 AM

E2E staff comment 1791137719676

Add a comment

Share an update visible to the Requester...

Figure 7.6: Ticket detail after actions mobile (detail segment 3/4).

Share an update visible to the Requester...

Post Comment

 **Internal Notes**

Internal — not visible to Requester

Regression Suite Staff Oct 5, 2026

E2E staff internal note

1791137719738

Add an internal note

Not visible to the Requester...

Post Internal Note

Figure 7.7: Ticket detail after actions mobile (detail segment 4/4).

 TokTickIT

Helpdesk

Regression Suite Staff IT Staff

Logout

Ticket Queue

[← Back to Queue](#)

TKT-2026-310282

IN PROGRESS

MEDIUM

Created Oct 5, 2026 • Last updated Oct 5, 2026

REQUESTER

Regression Suite Requester QA regression-suite-requester@toktick.internal

CATEGORY

Account and Access

RELATED SYSTEM

None / General IT

E2E fixture ticket 1791137717568

DESCRIPTION

Created by e2e/lab-03/staff-ticket-flow.spec.ts (I-9) for an isolated staff workflow run.

 Ownership & Priority

Figure 7.8: Ticket detail after actions tablet (detail segment 1/4).

Ownership & Priority

Owner updated.

Owner

Regression Suite Staff 

Requested Priority (read-only)

MEDIUM

IT Priority

HIGH 

Save IT Priority

IT Priority updated.

Status

Status updated.

Change status to

Select a status... 

Apply

Attachments (0)

No active attachments on this ticket.

Public Comments

Figure 7.9: Ticket detail after actions tablet (detail segment 2/4).

NO active attachments on this ticket.

Public Comments

Regression Suite Staff **IT Staff**
E2E staff comment 1791137719676

Oct 5, 2026, 01:15 AM

Add a comment

Share an update visible to the Requester...

Post Comment

Internal Notes **Internal — not visible to Requester**

Regression Suite Staff
E2E staff internal note 1791137719738

Oct 5, 2026

Add an internal note

Not visible to the Requester...

Post Internal Note

Figure 7.10: Ticket detail after actions tablet (detail segment 3/4).

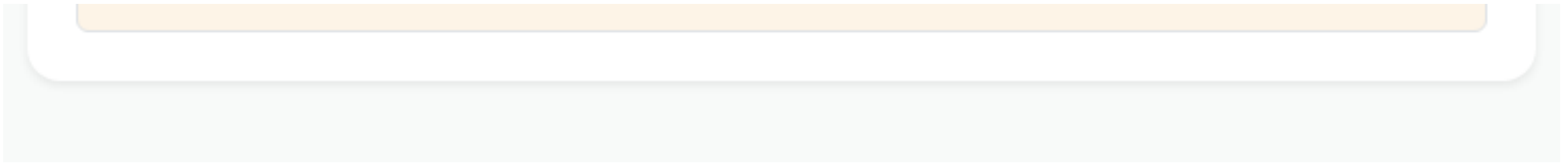


Figure 7.11: Ticket detail after actions tablet (detail segment 4/4).

Helpdesk

Regression Suite Staff IT Se

← Back to Queue

TKT-2026-310282

NEW

MEDIUM

Created Oct 5, 2026 • Last updated Oct 5, 2026

REQUESTER

Regression Suite Requester

QA

regression-suite-requester@toktick.internal

CATEGORY

Account and Access

RELATED SYSTEM

None / General IT

E2E fixture ticket 1791137717568

DESCRIPTION

Created by e2e/lab-03/staff-ticket-flow.spec.ts (I-9) for an isolated staff workflow run.

 Ownership & Priority

Figure 7.12: Ticket detail unclaimed desktop (detail segment 1/3).

Ownership & Priority

Owner

Unassigned



Claim

Requested Priority (read-only)

MEDIUM

IT Priority

MEDIUM



Save IT Priority

Status

Change status to

Select a status...



Apply

Attachments (0)

No active attachments on this ticket.

Public Comments

No comments yet on this ticket.

Add a comment

Share an update visible to the Requester...



Figure 7.13: Ticket detail unclaimed desktop (detail segment 2/3).

Share an update visible to the Requester...

Post Comment

 **Internal Notes** Internal — not visible to Requester

No internal notes yet.

Add an internal note

Not visible to the Requester...

Post Internal Note

Figure 7.14: Ticket detail unclaimed desktop (detail segment 3/3).

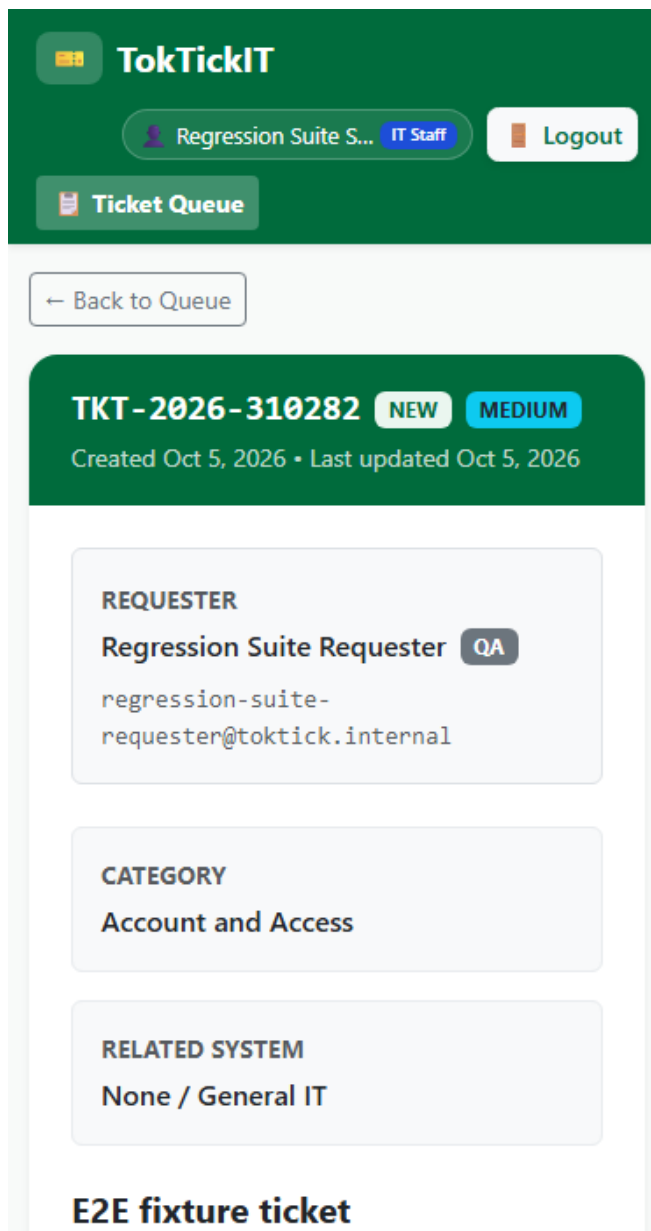


Figure 7.15: Ticket detail unclaimed mobile (detail segment 1/4).

E2E fixture ticket 1791137717568

DESCRIPTION

Created by e2e/lab-03/staff-ticket-flow.spec.ts (I-9) for an isolated staff workflow run.

Ownership & Priority

Owner

Unassigned

Claim

Requested Priority (read-only)

MEDIUM

IT Priority

MEDIUM

Save IT Priority

Status

Figure 7.16: Ticket detail unclaimed mobile (detail segment 2/4).

 **Status**

Change status to

Select a status... ▾

Apply

 **Attachments (0)**

No active attachments on this ticket.

 **Public Comments**

No comments yet on this ticket.

Add a comment

Share an update visible to the Requester...

Post Comment

 **Internal Notes**

Internal — not visible to Requester

No internal notes yet.

Add an internal note

Not visible to the Requester...

Figure 7.17: Ticket detail unclaimed mobile (detail segment 3/4).

Add an internal note

Not visible to the Requester...

Post Internal Note

Figure 7.18: Ticket detail unclaimed mobile (detail segment 4/4).

 TokTickIT

Helpdesk

Regression Suite Staff IT Staff

Logout

Ticket Queue

[← Back to Queue](#)

TKT-2026-310282

NEW

MEDIUM

Created Oct 5, 2026 • Last updated Oct 5, 2026

REQUESTER

Regression Suite Requester QA regression-suite-requester@toktick.internal

CATEGORY

Account and Access

RELATED SYSTEM

None / General IT

E2E fixture ticket 1791137717568

DESCRIPTION

Created by e2e/lab-03/staff-ticket-flow.spec.ts (I-9) for an isolated staff workflow run.

 Ownership & Priority

Figure 7.19: Ticket detail unclaimed tablet (detail segment 1/3).

Ownership & Priority

Owner

Unassigned



Claim

Requested Priority (read-only)

MEDIUM

IT Priority

MEDIUM



Save IT Priority

Status

Change status to

Select a status...



Apply

Attachments (0)

No active attachments on this ticket.

Public Comments

No comments yet on this ticket.

Add a comment

Share an update visible to the Requester...



Figure 7.20: Ticket detail unclaimed tablet (detail segment 2/3).

Share an update visible to the Requester...

Post Comment



Internal Notes

Internal — not visible to Requester

No internal notes yet.

Add an internal note

Not visible to the Requester...

Post Internal Note

Figure 7.21: Ticket detail unclaimed tablet (detail segment 3/3).

Direct API authorization evidence follows. The 404 for another Requester's Ticket is intentional existence masking (BR-32), not an endpoint failure.

TokTickIT – Part 7 Direct API Authorization Evidence

Captured 2026-09-17 against a running local server + the real dev database.

Cookie-jar curl transcripts (D-01: session is an httpOnly cookie, no bearer token to paste).

```
=====
Scenario 1: Requester -> Internal Notes (expect 403, no note content at all)
=====
$ curl -c jar.txt -X POST localhost:3000/api/auth/login -d '{"email":"regression-suite-requester@toktick.internal","password":"..."}'
(logged in as REQUESTER regression-suite-requester@toktick.internal)

$ curl -b jar.txt -i localhost:3000/api/tickets/232/internal-notes
HTTP/1.1 403 Forbidden
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 93
ETag: W/"5d-dhyf7VaPnYE+oUZ7Wz4c7KZPZDY"
Date: Thu, 17 Sep 2026 10:54:06 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error":{"code":"FORBIDDEN","message":"You do not have permission to perform this action."}}

=====
Scenario 2: Requester -> IT Staff Ticket Queue (expect 403)
=====
$ curl -b jar.txt -i localhost:3000/api/staff/tickets
HTTP/1.1 403 Forbidden
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 93
ETag: W/"5d-dhyf7VaPnYE+oUZ7Wz4c7KZPZDY"
Date: Thu, 17 Sep 2026 10:54:17 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error":{"code":"FORBIDDEN","message":"You do not have permission to perform this action."}}

=====
Scenario 3: Requester -> another Requester's Ticket (expect 404, not 403 -- BR-32 deliberate masking)
=====
(Ticket 146 belongs to a DIFFERENT requester; acting as regression-suite-requester)
$ curl -b jar.txt -i localhost:3000/api/tickets/146
HTTP/1.1 404 Not Found
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 60
ETag: W/"3c-WrYm90Z1bysX94+dvywzxwbto5o"
Date: Thu, 17 Sep 2026 10:54:17 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error":{"code":"NOT_FOUND","message":"Ticket not found."}}

=====
Scenario 4: IT Staff -> Administrator user management (expect 403)
=====
$ curl -c jar.txt -X POST localhost:3000/api/auth/login -d '{"email":"regression-suite-staff@toktick.internal","password":"..."}'
(logged in as IT_STAFF regression-suite-staff@toktick.internal)
$ curl -b jar.txt -i localhost:3000/api/admin/users
```

```
HTTP/1.1 403 Forbidden
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 93
ETag: W/"5d-dhyf7VaPhYE+oUZ7Wz4c7KZPZDY"
Date: Fri, 18 Sep 2026 09:04:46 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

```
{"error":{"code":"FORBIDDEN","message":"You do not have permission to perform this action."}}
```

NOTE (re-captured 2026-09-18, review of PR #69 item 2): this scenario previously showed a route-not-found 404 ("Cannot GET /api/admin/users") with a note deferring re-capture "once I-8's routes exist" – I-8 (Administrator User Management) has since landed, and this transcript now shows the real role-based 403 the scenario was always meant to demonstrate: IT_STAFF is authenticated but not permitted to access Administrator-only routes.

```
=====
Scenario 5: Unauthenticated -> any protected route (expect 401)
=====
```

```
$ curl -i localhost:3000/api/staff/tickets (no cookie jar at all)
HTTP/1.1 401 Unauthorized
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 64
ETag: W/"40-bNFVsZ5lu9ruW2BnUy/fxo8YuaA"
Date: Thu, 17 Sep 2026 10:54:30 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

```
{"error":{"code":"UNAUTHENTICATED","message":"Login required."}}
```

```
=====
Scenario 6: mustChangePassword=true user -> any non-allowlisted app route (expect 403)
=====
```

```
$ curl -c jar.txt -X POST localhost:3000/api/auth/login -d
'{"email":"jennifer.anderson@toktick.internal","password":"ChangeMe123!"}'
(jennifer.anderson is a Lab-2-evolved seed Requester who has never completed the forced initial
password change)
```

```
$ curl -b jar.txt -i localhost:3000/api/tickets
HTTP/1.1 403 Forbidden
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 106
ETag: W/"6a-KBUG5u1g43YeXQQ3A5m5F5y5YHk"
Date: Thu, 17 Sep 2026 10:54:49 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

```
{"error":{"code":"PASSWORD_CHANGE_REQUIRED","message":"You must change your password before
continuing."}}
```

```
=====
Bonus (I-7 positive path): IT Staff claims a ticket, then makes an
illegal status transition, then a legal one -- as direct evidence for
BR-13/BR-17/BR-19 alongside the negative-path scenarios above.
=====
(still authenticated as IT_STAFF regression-suite-staff, jar-staff.txt)
```

```
$ curl -b jar.txt -i localhost:3000/api/staff/tickets/232
HTTP/1.1 200 OK
X-Powered-By: Express
```

```
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 1029
ETag: W/"405-3C9nvxUt+51Y9dNQjs04WkN/mMs"
Date: Thu, 17 Sep 2026 10:55:02 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

```
{"id":232,"ticketNumber":"TKT-2026-TEST206584","summary":"Updated Summary for In-Place Edit Test","description":"Created directly for ticket-detail.api.test.ts, owned by the regression requester.", "categoryId":1,"category":{"id":1,"name":"Account and Access","createdAt":"2026-09-01T13:36:41.478Z"},"relatedSystemId":null,"relatedSystem":null,"requestedPriority":"URGENT","itPriority":"MEDIUM","status":"NEW","permittedStatusTransitions":["OPEN","IN_PROGRESS","CANCELLED"],"ownerId":null,"owner":null,"requesterId":41,"requester":{"id":41,"name":"Regression Suite Requester","email":"regression-suite-requester@toktick.internal","department":"QA","role":"REQUESTER","passwordHash":"[REDACTED]","mustChangePassword":false,"isActive":true,"lastLoginAt":"2026-09-17T10:54:06.554Z","createdAt":"2026-09-16T11:59:04.561Z","updatedAt":"2026-09-17T10:54:06.556Z"},"attachments":[],"requesterResolvedAt":null,"createdAt":"2026-09-17T10:50:06.586Z","updatedAt":"2026-09-17T10:50:06.632Z"}
```

FINDING: the response above includes the requester's full User row, including `passwordHash` (a bcrypt hash). Capturing this transcript is what surfaced the bug – `include: { requester: true }` fetched every User field into every ticket response across five routes (three pre-existing since I-2, plus this new I-7 route). Fixed immediately in this same branch by introducing `SAFE\_REQUESTER\_SELECT` (server/src/app.ts) and applying it to all five includes; two regression tests added (server/tests/lab-02/ticket-detail.api.test.ts and server/tests/lab-03/staff-ticket-detail.api.test.ts, both "SEC-01") assert no ticket response ever contains `passwordHash` again. The "Verification" section below re-runs this exact request after the fix.

NOTE (added after PR #68 review): the value shown as `[REDACTED]` above was a real bcrypt hash in the version of this file first committed and pushed. It was redacted by amending and force-pushing that commit, which removes it from this branch's reachable history (what a clone or diff of the branch tip shows) but does NOT purge the underlying git object from GitHub's storage – the original commit remains fetchable by its exact SHA. A true purge would require GitHub Support. Treated as low practical risk since it is a regression-test fixture account whose plaintext password is already committed in source (server/tests/helpers/testAuth.ts), not a production credential – but recorded accurately here rather than implying full removal.

```
$ curl -b jar.txt -X PATCH -H 'Content-Type: application/json' -d '{"status":"RESOLVED"}' -i localhost:3000/api/staff/tickets/232/status
(ticket 232 is NEW; NEW -> RESOLVED is not in the $6.5 matrix -- expect 409 with the permitted set)
HTTP/1.1 409 Conflict
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 86
ETag: W/"56-v1H8o3TxazgY0gEl85t5mkQQcCE"
Date: Thu, 17 Sep 2026 10:55:02 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

```
{"error":{"code":"ILLEGAL_TRANSITION","permitted":["OPEN","IN_PROGRESS","CANCELLED"]}}
```

```
=====
Verification: GET /api/staff/tickets/:id no longer leaks passwordHash
(re-run after the SAFE_REQUESTER_SELECT fix above)
=====
```

```
$ curl -b jar.txt -i localhost:3000/api/staff/tickets/232
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: http://localhost:5173
Vary: Origin
Access-Control-Allow-Credentials: true
Content-Type: application/json; charset=utf-8
Content-Length: 770
```

ETag: W/"302-Q30zW2JXiFSlwwy5bRmcGequdvs"

Date: Thu, 17 Sep 2026 10:57:30 GMT

Connection: keep-alive

Keep-Alive: timeout=5

```
{"id":232,"ticketNumber":"TKT-2026-TEST206584","summary":"Updated Summary for In-Place Edit
Test","description":"Created directly for ticket-detail.api.test.ts, owned by the regression
requester.","categoryId":1,"category":{"id":1,"name":"Account and Access","createdAt":"2026-09-
01T13:36:41.478Z"},"relatedSystemId":null,"relatedSystem":null,"requestedPriority":"URGENT","it
Priority":"MEDIUM","status":"NEW","permittedStatusTransitions":["OPEN","IN_PROGRESS","CANCELLED
"],"ownerId":null,"owner":null,"requesterId":41,"requester":{"id":41,"name":"Regression Suite
Requester","email":"regression-suite-requester@toktick.internal","department":"QA"},"attachmen
ts":[],"requesterResolvedAt":null,"createdAt":"2026-09-17T10:50:06.586Z","updatedAt":"2026-09-
17T10:50:06.632Z"}
```

Answer Part 8: Working Administrator User Management UI

The list and create/edit dialogs are shown at desktop, tablet and mobile sizes. Admin API/UI/E2E tests verify create, search, edit, initial-password reset, duplicate-email/invalid-input handling, self-deactivation and last-Administrator safety, and non-Admin rejection.

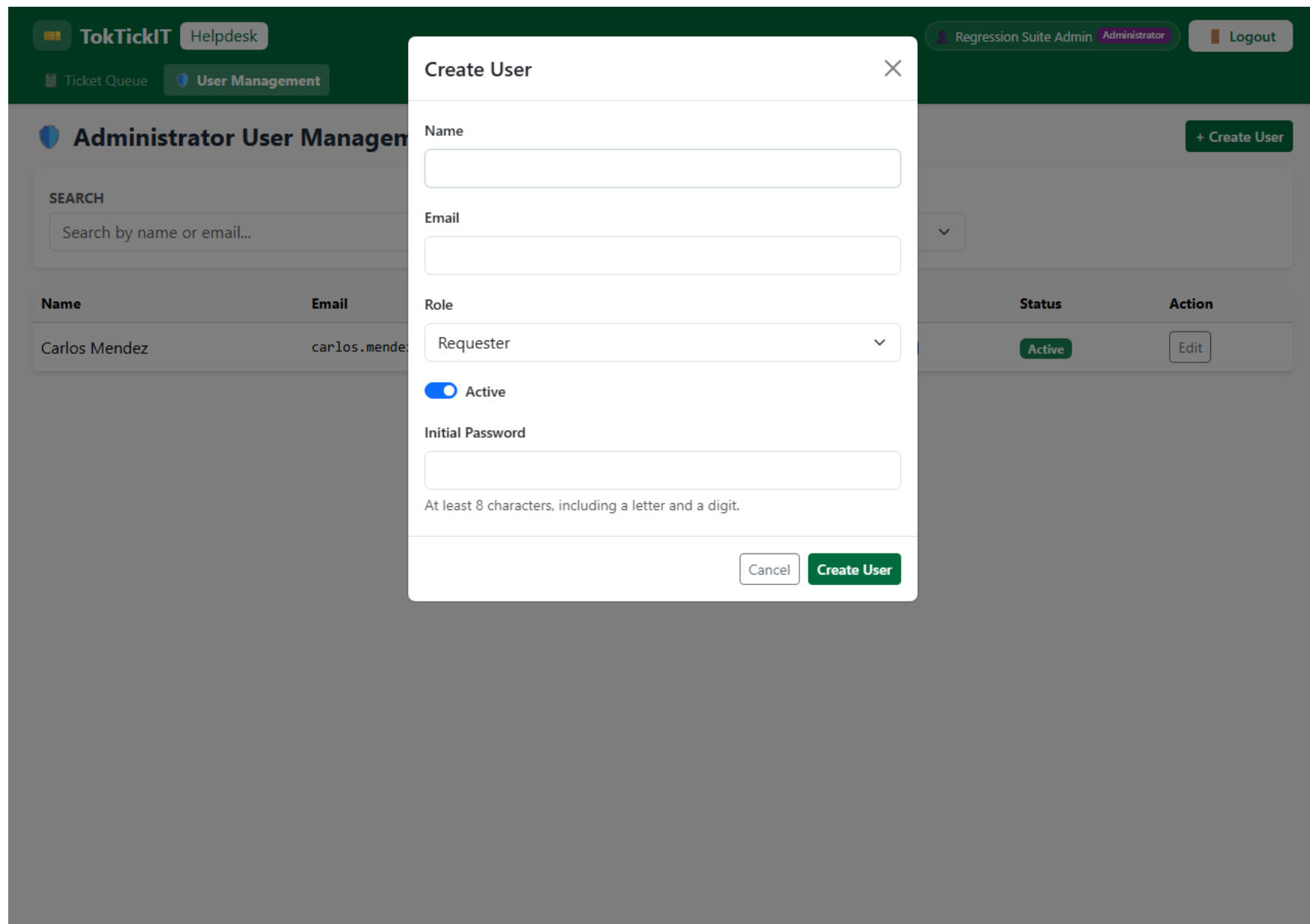


Figure 8.1: Create user modal desktop.

Create User

×

Name

Email

Role

Requester

▼

☒ Active

Initial Password

At least 8 characters, including a letter and a digit.

Cancel

Create User

Figure 8.2: Create user modal mobile.

The image shows a web application interface for 'TokTicket Helpdesk' in an 'Admin' role. A modal titled 'Create User' is open, allowing the creation of a new user. The modal contains the following fields and controls:

- Name:** A text input field.
- Email:** A text input field.
- Role:** A dropdown menu with 'Requester' selected.
- Active:** A toggle switch that is currently turned on.
- Initial Password:** A text input field with a note below it: 'At least 8 characters, including a letter and a digit.'

At the bottom of the modal are two buttons: 'Cancel' and 'Create User'.

In the background, the admin interface includes a top navigation bar with 'TokTicket Helpdesk', 'Logout', and a '+ Create User' button. A sidebar on the left has a 'SEARCH' section and a table with the following content:

Name
Carlos Mendez

The table also has an 'Action' column with an 'Edit' button.

Figure 8.3: Create user modal tablet.

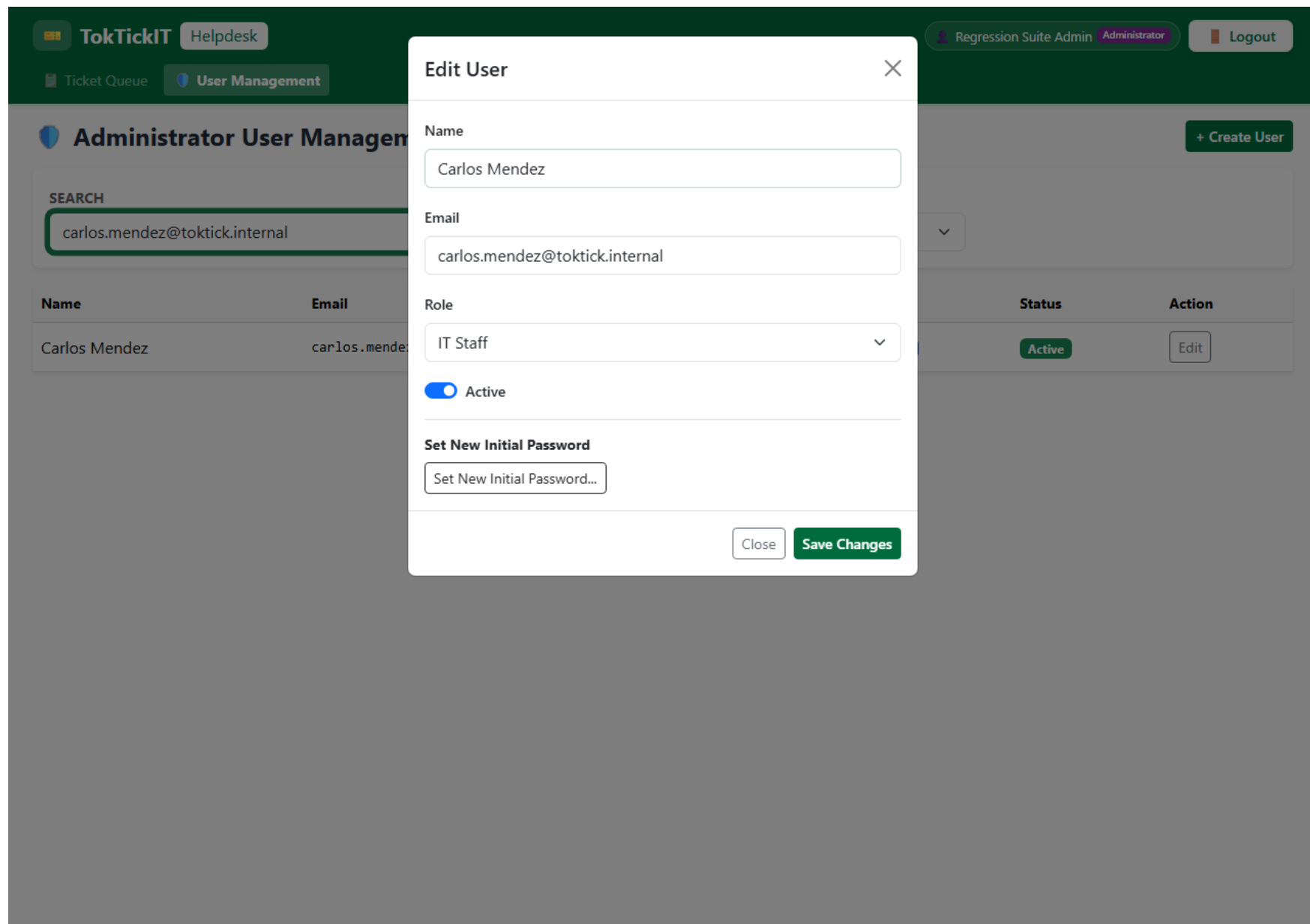


Figure 8.4: Edit user modal desktop.

Edit User

Name

Carlos Mendez

Email

carlos.mendez@toktick.internal

Role

IT Staff

☒ Active

Set New Initial Password

Set New Initial Password...

Close

Save Changes

Figure 8.5: Edit user modal mobile.

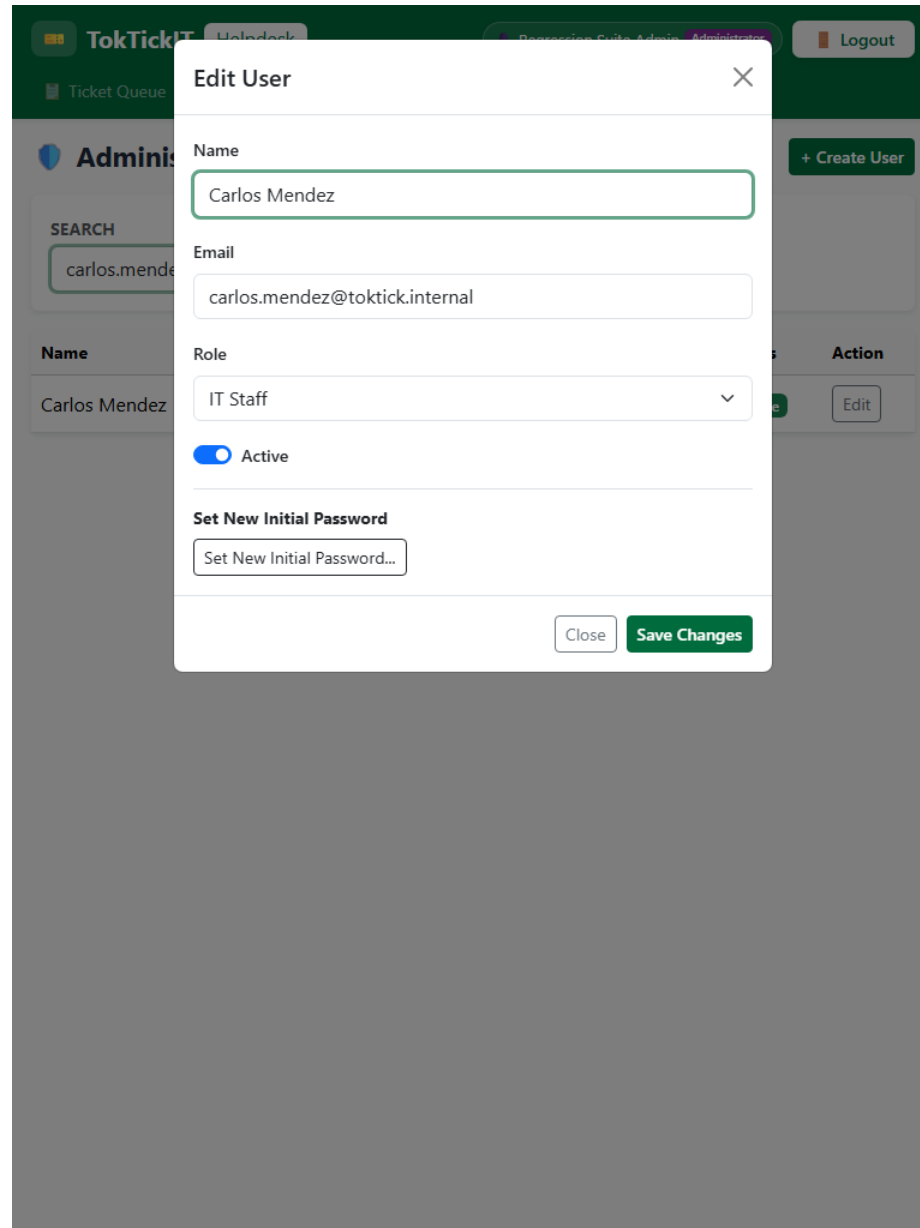


Figure 8.6: Edit user modal tablet.

TokTickIT

Helpdesk

Ticket Queue

User Management

Regression Suite Admin

Administrator

Logout

Administrator User Management

+ Create User

SEARCH

carlos.mendez@toktick.internal

ROLE

IT Staff

Name	Email	Role	Status	Action
Carlos Mendez	carlos.mendez@toktick.internal	IT Staff	Active	Edit

Figure 8.7: User list desktop.

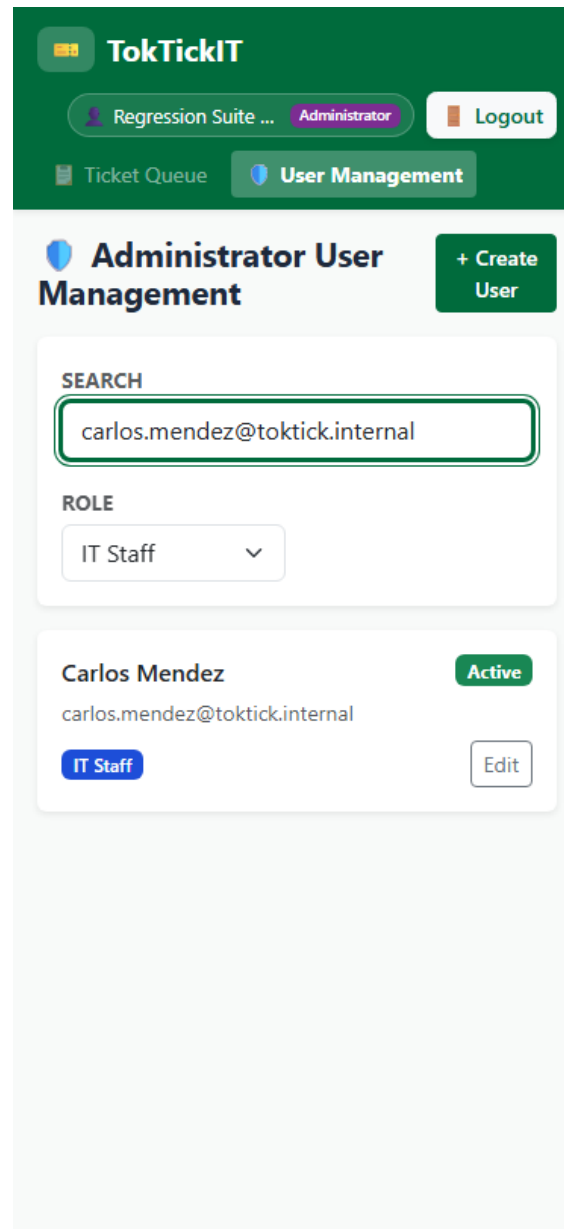


Figure 8.8: User list mobile.

TokTickIT

Helpdesk

Regression Suite Admin

Administrator

Logout

Ticket Queue

User Management

Administrator User Management

+ Create User

SEARCH

carlos.mendez@toktick.internal

ROLE

IT Staff

Figure 8.9: User list tablet.

Answer Part 9: Zen Green UI and Responsive Evidence

The galleries in Parts 5–8 contain the desktop/tablet/mobile variants for every major Lab 3 screen. The rendered UI specification below includes the completed visual checklist; VIS-01–VIS-06 document the computed-color, focus, clipping, overflow and responsive browser assertions.

UI specification source: [ui-spec.md](#).

Rendered document: `docs/lab-03/ui-spec.md`

Lab 3 UI Specification — Zen Green Design System Extension

This document extends `docs/lab-02/ui-spec.md`. All Lab 2 tokens, form conventions, button hierarchy, and priority badges remain unchanged and in force. This document adds only what Lab 3 introduces: authentication screens, role badges, status badges for the 8-state workflow, the IT Staff screens, and the Administrator screen.

1. New Design Tokens

Token Name: `--color-role-requester` | Hex Code: `#0B7A46`

Purpose: Requester role badge (reuses secondary green)

Token Name: `--color-role-staff` | Hex Code: `#1D4ED8`

Purpose: IT Staff role badge

Token Name: `--color-role-admin` | Hex Code: `#7C2D92`

Purpose: Administrator role badge

Token Name: `--color-status-open` | Hex Code: `#EAF6EF` bg / `#006B3C` text

Purpose: `NEW`, `OPEN`

Token Name: `--color-status-progress` | Hex Code: `#DBEAFE` bg / `#1D4ED8` text

Purpose: `IN_PROGRESS`

Token Name: `--color-status-waiting` | Hex Code: `#FEF3C7` bg / `#B45309` text

Purpose: `WAITING_FOR_REQUESTER`

Token Name: `--color-status-resolved` | Hex Code: `#D1FAE5` bg / `#047857` text

Purpose: `RESOLVED`

Token Name: `--color-status-closed` | Hex Code: `#F1F5F9` bg / `#475569` text

Purpose: `CLOSED`

Token Name: `--color-status-reopened` | Hex Code: `#FFEDD5` bg / `#C2410C` text

Purpose: `REOPENED`

Token Name: `--color-status-cancelled` | Hex Code: `#FEE2E2` bg / `#991B1B` text

Purpose: `CANCELLED`

Token Name: `--color-internal-note-bg` | Hex Code: `#FDF4E7`

Purpose: Internal Note panel background — visually distinct from Public Comment

Token Name: `--color-public-comment-bg` | Hex Code: `#F5F7F6`

Purpose: Public Comment panel background (matches page canvas)

All existing Requested/IT Priority badges from Lab 2 §4 are reused unchanged for both Requested Priority and IT Priority — the two are distinguished by a label ("Requested" vs "IT Priority"), never by a different color scale.

2. Screen: Login

- Centered card, max-width 420px, on the Zen Green pale background.
- Fields: Email, Password (masked, with a show/hide toggle).
- Primary button: "Log In" (`.btn-zen-primary`), full width.
- States: idle busy (spinner, "Logging in...", button disabled) success (redirect) or error (inline banner above the form, `--color-error-bg`, generic "Invalid email or password" or "This account has been deactivated.").
- No indication of which field was wrong (BR-06).

3. Screen: Change Password (mandatory first-login)

- Same card treatment as Login. Not dismissible — no navigation away is possible until submitted successfully.
- Fields: Current Password, New Password, Confirm New Password.
- Inline password rules shown as a checklist that ticks green as satisfied (≥ 8 chars, contains a letter, contains a digit, matches confirmation).
- On success: redirect into the application shell with a brief success toast.

4. Application Shell (all authenticated screens)

- Navbar (extends Lab 2's `Navbar.tsx`): replaces the "Requester: Name (Department)" pill and "Change Requester" button with:
 - The current user's name and a role badge (`--color-role-*`).
 - Role-specific navigation links — a Requester never sees "Ticket Queue" or "User Management"; an IT Staff never sees "User Management"; an Administrator sees both "Ticket Queue" and "User Management", matching the explicit Administrator permissions in the project authorization matrix.
- A "Logout" button (`.btn-zen-secondary`), always visible.
- Direct navigation to a route outside the current role's permitted set redirects to `/login` (if unauthenticated) or to the role's default screen (if authenticated but forbidden) — never a blank page or a client-side crash.

5. Requester Screens (Lab 2 continuation)

- Create Ticket, My Tickets, Ticket Detail — unchanged visually from Lab 2.
- Ticket Detail adds:
 - A Public Comments panel below Attachments: a chronological list of `{ author, timestamp, body }`, an add-comment textarea, "Post Comment" button. Background `--color-public-comment-bg`.
 - A "Problem Appears Resolved" button (`.btn-zen-secondary`), visible only while status is not already `RESOLVED/CLOSED/CANCELLED`. After use, replaced with a small "You indicated this is resolved on {date}" note; does not alter the visible status badge.

6. Screen: IT Staff Ticket Queue

- Desktop ($\geq 992\text{px}$): data table — Ticket Number, Created Date, Summary, Category, Requested Priority, IT Priority, Status, Owner, Last Updated, action ("Open"). Chosen over a wider grid to keep every column legible without horizontal scroll at 1280px .
- Tablet ($768\text{--}991\text{px}$): condensed table (Ticket Number, Summary, Status, IT Priority, Owner, Open) inside a horizontal-scroll container, or a card list — implementation may choose either provided zero page-level overflow.
- Mobile ($< 768\text{px}$): Ticket Cards — Ticket Number, Summary, Status badge, IT Priority badge, Owner ("Unassigned" in muted gray if null), tap to open.
- Controls: search box; filters for Status, IT Priority, Category, Owner (including an explicit "Unassigned" option); column-header sort on supported fields; pagination controls (page size fixed at 10, per `api-spec.md`).
- Feedback states: loading skeleton rows; empty state ("No tickets in the queue yet"); no-results state ("No tickets match your filters" + Clear Filters); forbidden state (if reached by a non-staff role, redirect rather than render); safe failure banner on API error.
- Unassigned rows show an "Unassigned" pill in `--color-border-subtle` gray; assigned rows show the owner's name.

7. Screen: IT Staff Ticket Detail

Extends the Requester Ticket Detail layout with an operational panel, grouped distinctly from the read-only Ticket information:

- Ownership & Priority panel: current owner (or "Unassigned" + "Claim" button), a reassign dropdown (active IT Staff/Administrator only), IT Priority selector (independent of the read-only Requested Priority shown alongside it).
- Status control: a dropdown/segmented control offering only the transitions permitted from the current status (per the transition matrix); attempting an out-of-band change is prevented client-side and rejected server-side regardless.
- Public Comments panel: identical to the Requester's, editable by staff too.
- Internal Notes panel: visually distinct — `--color-internal-note-bg` background, a small "Internal — not visible to Requester" label pinned to the panel header, so it cannot be mistaken for the Public Comments panel above/below it.
- Existing Lab 2 Attachments panel is unchanged and continues to function.
- All edits show inline validation, a saving spinner state, a success toast, and a safe failure banner (no raw error text) on API failure.

8. Screen: Administrator User Management

A single screen, list + modal forms — deliberately minimal per scope:

- List (desktop table / mobile cards): Name, Email, Role badge, Status

badge (Active/Inactive), Edit action.

- Search bar (name or email) + optional role filter dropdown

(All/Requester/IT Staff/Administrator). No pagination, no multi-column sort, no multiple simultaneous filters — matches the excluded scope.

- Create User modal: Name, Email, Role (single-select), Active toggle,

Initial Password field. Duplicate-email and invalid-role errors render inline beneath the offending field.

- Edit User modal: Name, Email, Role, Active toggle, and a separate "Set

New Initial Password" action (its own confirmation step, since it forces the target user's next login into Change Password).

- Self-deactivation and last-Administrator-removal attempts are blocked with

an inline error banner explaining why, never a silent no-op.

- Non-Administrator access redirects away before the screen renders.

9. Responsive Rules

Same breakpoints as Lab 2 (`ui-spec.md §5`): Desktop $\geq 992\text{px}$, Tablet $768\text{--}991\text{px}$, Mobile $< 768\text{px}$, with zero horizontal scrolling at 375px as a hard rule for every new screen listed above.

10. Visual Inspection Checklist (Lab 3 additions)

- [x] Role badges (`--color-role-*`) and role-specific destinations render

correctly across the Requester workspace, Staff Queue/Detail, and Administrator Queue/Detail/User Management screens. Verified in `e2e/lab-03/visual-inspection.spec.ts` by signing in as all three roles, checking the computed badge background against each `--color-role-*` value, checking allowed destinations, and navigating through each role's authenticated screens.

- [x] Each status badge uses its declared background/text tokens in §1, rather

than only differing from a Priority badge. Verified in `e2e/lab-03/visual-inspection.spec.ts` by filtering to each of the eight statuses and comparing computed background and text colors to the specification.

- [x] Public Comments and Internal Notes panels are visually distinguishable

at a glance, including on a 375px screen where they stack vertically. Verified in `e2e/lab-03/visual-inspection.spec.ts` ("panel backgrounds differ on a mobile viewport") by comparing computed background colors of the Internal Notes panel (`--color-internal-note-bg`) and the Public Comments section at a 375px viewport on Staff Ticket Detail.

- [x] Editable vs. read-only fields (Requested Priority vs. IT Priority) are

distinguishable using the Lab 2 read-only background convention. Verified in `e2e/lab-03/visual-inspection.spec.ts` ("Requested Priority renders as static text while IT Priority renders as a select") by asserting the Requested Priority container contains no `<select>/<input>` while `#it-priority-select` is a real, interactive `<select>`.

- [x] The Queue shows "Unassigned" as a read-only label; Ticket Detail

offers an enabled Owner `<select>` for the same unassigned ticket. Verified semantically in `e2e/lab-03/visual-inspection.spec.ts` by selecting an unassigned queue row, opening it, and checking the label, control type, and selected value. This does not claim a measured visual-contrast threshold between the two controls.

- [x] Validation feedback appears in the location specified for each form:

Login and Change Password use an inline alert banner; Create/Edit User errors appear beneath the offending field. Verified in `e2e/lab-03/visual-inspection.spec.ts` with invalid login credentials, a weak forced-change password, a weak initial password on Create User, and a duplicate email on Edit User.

- [x] Focus states are visible on every visible, enabled keyboard control.

`auditEveryVisibleTabStop` in `e2e/lab-03/visual-inspection.spec.ts` walks real Tab order and checks a visible focus indicator on Login and Change Password, Requester My Tickets/Create/Detail/Edit, Staff and Administrator Queue/Detail, and Administrator User List/Create/Edit (including the set-initial-password state). It covers the mobile Requester list/create, mobile Staff Queue cards, mobile Administrator User List, and tablet Staff Queue as well as desktop layouts. The same suite verifies that Add Attachment is keyboard-operable and that the attachment-removal and Administrator user dialogs close on Escape and restore focus to their openers. The attachment-removal dialog also has an accessible name, contains focus, and can be confirmed from the UI. Keyboard activation of sortable headers and ticket cards is also exercised. Disabled controls are not Tab stops and are not included in the focus sweep.

- [x] No clipping of role badges, status badges, or owner names at 375px.

Verified in `e2e/lab-03/visual-inspection.spec.ts` ("mobile ticket cards keep status/priority badges and owner name within the viewport") via each ticket card's `boundingBox()` at a 375px viewport on the Staff Queue.

- [x] No horizontal overflow on the Staff Queue table at any breakpoint.

Verified in `e2e/lab-03/visual-inspection.spec.ts` at all three viewports (1280/768/375px) by asserting `document.documentElement.scrollWidth <= document.documentElement.clientWidth`.

- [x] No page-level horizontal overflow at 375px across the Lab 3 screens:

Login, forced password change, Requester My Tickets/Create/Detail, Staff Queue/Detail, Administrator Queue/User List/Create modal/Edit modal. Verified by checking the document width against the viewport at each state in `e2e/lab-03/visual-inspection.spec.ts`.

- [x] Forbidden and not-found states never render a blank screen or an

unstyled browser error page. Verified in `e2e/lab-03/visual-inspection.spec.ts`: an IT Staff session hitting the Administrator-only `/admin/users` is redirected (not blank, and the resulting page has non-empty body text), an unauthenticated session hitting `/staff/queue` lands on a rendered `/login` form rather than a blank page, and (added in review of PR #70, item 6) a genuinely nonexistent ticket ID at `/staff/tickets/99999999` renders a styled `.alert-danger` error message with a working "Back to Queue" button rather than a blank screen — `StaffTicketDetail.tsx`'s `loadError` branch already handled this correctly; it just had no test hitting the real not-found path.